IST606 SECURITY MANAGEMENT AND COMPUTER FORENSICS

OBJECTIVES

- Two objectives:
  - Issues related to administration and management of security of information systems and networks
  - Approaches to perform computer crime investigations.
- The course covers the **recovery** and **analysis** of digital evidence, addressing **legal** and **technical** issues.
- Forensic examination techniques of Windows and Unix systems are used to illustrate typical investigative processes.

COURSE OUTLINE – PART ONE

- Introduction to information security
- Information security concepts
  - Vulnerability and abuse
  - Vulnerability analysis
- Classification of vulnerabilities
- Security and monitoring information systems
- Analysis and assessment of information system risks

PLAN

- Introduction to information security
  - Why information security matters
  - Information sensitivity classification
  - Information security governance
  - How to secure a computing environment
  - Main classes of security controls: managerial, operational, and technical

PLAN

- Information security management concepts
  - Selected management concepts
  - Required managerial skills
  - Strategic management concepts
  - IS security management activities
  - Information security (IS) management cycle
  - IS management cycle in relation with management concepts
  - Roles and responsibilities of an IS manager

PLAN

- Information security life cycle
  - What is security life cycle (SLC)
  - How a security life cycle is planned
  - How security is analyzed in the security life cycle
  - How to conduct an impact analysis
  - How to compute asset exposures to threats
  - How to conduct a risk analysis
  - How to design security in the security life cycle
  - How to mitigate security risks
  - How to review security in the security life cycle

PLAN

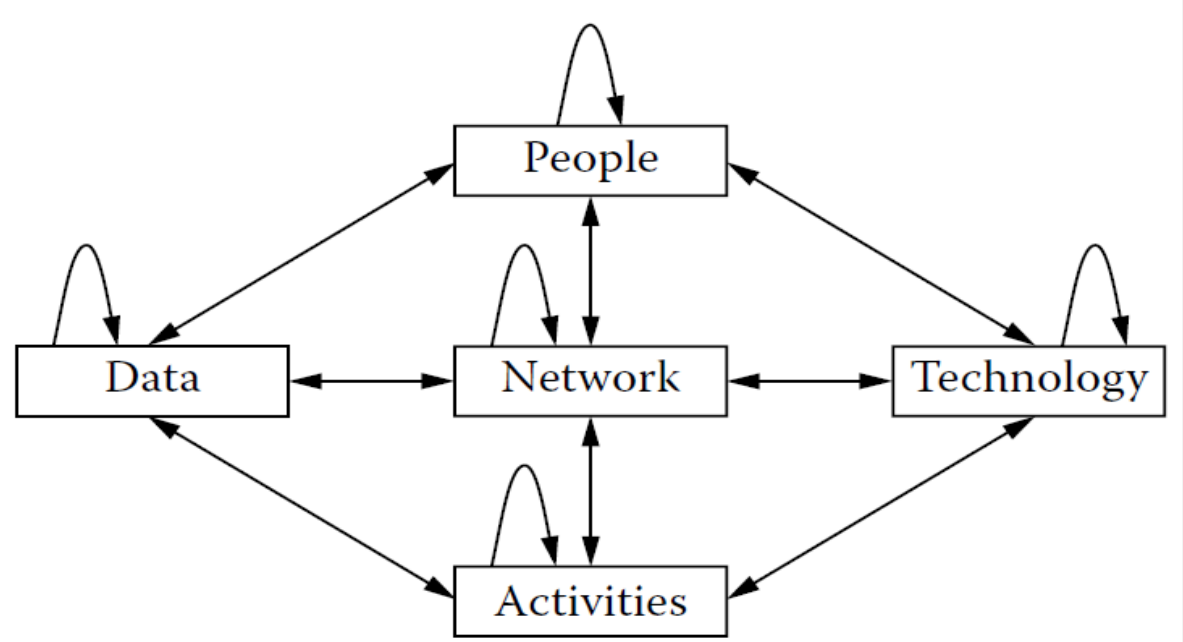
- Information security risk management
  - What security risk management is
  - How security risk management works
  - What strategic, functional, and operational risks are
  - How security risk is mitigated
  - How productivity, security compromise, and recovery work together

PLAN

- Active security assessment
  - Standards for active security assessment
  - Limits of active security assessment
  - The vulnerabilities of various components of the computing environment
  - Strategies for active security assessment
  - The active security assessment project
  - How to conduct passive security assessment
  - How to conduct the active security assessment effort

INTRODUCTION TO INFORMATION SECURITY: WHY?

- Why information security?
  - There is no security out of an environment, particularly an organization.
  - An organization is viewed as a composite environment made of peoples, smaller computing environments and information systems.
  - A computing environment is made up of five continuously interacting components:
    - Activities
    - People
    - Data
    - Technology
    - Networks



INTRODUCTION TO INFORMATION SECURITY

- Why information security?
  - An information system is also viewed as a smaller computing environment made up of activities, people, data, technology, and networks that continuously interact to efficiently achieve information system objectives.
  - It is then important and critical to discuss security interdependence and emphasize that all information system components must be secured in order to achieve information system security.

INTRODUCTION TO INFORMATION SECURITY

- Information security is now better understood by organizations
  - In majority, organization (even people) experienced the undesired events that affected their computing environment and information systems.
  - Theft, damage, or destruction of computer systems, Corruption or destruction of corporate data
  - Leakage of sensitive information to rivals, Stealing private information for employees, customers, or partners
  - Damage to the reputation of an organization, Denial of service that caused business loss

INTRODUCTION TO INFORMATION SECURITY: WHY?

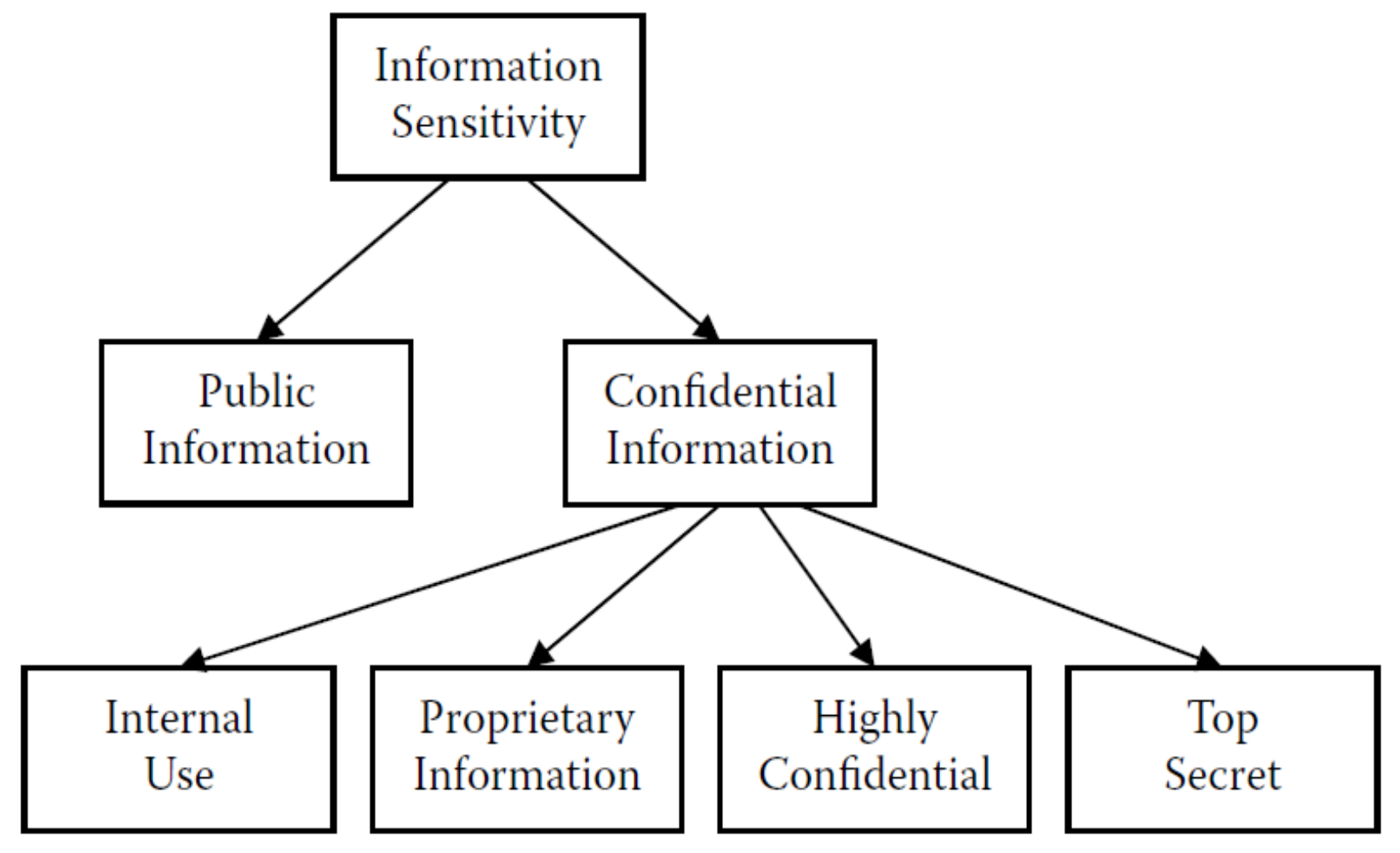
- Enterprise business value generation capability is driven by information.
- If this information is
  - accurate,
  - complete,
  - timely,
- Then there is business value;
- Otherwise, there will be weak business value generation.
- If a rival gets hold of some of this information, the consequences will be catastrophic.
- Any information security investigation must be risk driven.
- Then, the necessity of classification.

INFORMATION SECURITY: CLASSIFICATION

- Information sensitivity classification
- Information should, be classified in terms of the
  - **Value added** to the organization
  - Its **sensitivity** level.
- A sensitivity taxonomy should be simple to understand and easy to apply.
- It should also be effective in classifying assets in terms of their level of sensitivity.
- Information can be organized as **Public** and **Confidential.**
  - **Public information** is set to be public, and it may be shared by all.
  - **Confidential information** should be shared with recipients who are explicitly authorized to obtain it.

INFORMATION SECURITY: CLASSIFICATION

- Information sensitivity classification



INFORMATION SECURITY: CLASSIFICATION

- Information sensitivity classification
- ISO/IEC 17799 or ISO/IEC 27002 classify information as follow:
  - Public: can be made public without undesirable consequences. Web access, commercial site, annual reports, … etc.
  - Internal use: public for the organization, but confidential thus not authorized to become public (out of the organization). Announcements, minutes of meetings, … etc.
  - Proprietary: produced by in-house resources, hardware, software, or methodology. Operational information, design methodology, … etc.

INFORMATION SECURITY: CLASSIFICATION

- Information sensitivity classification
- ISO/IEC 17799 or ISO/IEC 27002 classify information as follow:
  - Highly confidential: highly critical information that is not top secret but is considered critical to the organization's ongoing operations and could vitally hinder the organization's capability of business continuity. Accounting information, new business plans, new products, and new technology, … etc.
  - Top secret: highly sensitive internal data, divulgation to an unauthorized person can be catastrophic. Military information, strategic plan, research and development, … etc.

INTRODUCTION TO INFORMATION SECURITY: GOVERNANCE

- Information security governance
- It is described as being similar in nature to corporate governance and IT governance.
- They share functionality and goals.
- Even though they have different focuses, all the three concepts work within an organizational structure of a company, and they aim at ensuring, that the company grows and prospers.

INTRODUCTION TO INFORMATION SECURITY: GOVERNANCE

- Information security governance
  - Corporate governance is concerned with how the board of directors and executive management run and control a company,
  - IT governance is more concerned with **how technology** is used and managed to support business needs.
- **Security governance** is the set of responsibilities and practices exercised by the board and executive management with the goal of providing strategic direction, ensuring that objectives are achieved, ascertaining that risks are managed appropriately and verifying that the enterprise's resources are used responsibly.

INTRODUCTION TO INFORMATION SECURITY

- How to secure computing environment
  - There is no security without specifying the resource to be secured
- Computing environment is made of five main resources:
  - People: actors, use, share, publish through network, … etc.
  - Activities: made by people on data or information, shared, … etc.
  - Data: collect, aggregate, compute, share in and out of the company, … etc.
  - Technology: supports for data, information, network and used by people.
  - Network: support for data and information transmission.
- The security of information systems should be understood in terms of the security of all its components: people, its activities, its data, its technology, its network.

INTRODUCTION TO INFORMATION SECURITY

- Information security is often expressed in terms of
  - Information confidentiality (C): protection of information from unauthorized access or disclosure
  - Information integrity (I): protection of information from unauthorized modification
  - Information availability (A): obtains the required information from the appropriate resource
- They are often denoted CIA components.
- Information security means protecting information from unauthorized interactions.

INTRODUCTION TO INFORMATION SECURITY

- The only authorized interactions are the ones defined in the security policy of the information resource containing the information.
- Interactions include access to the information and its **use**, **disclosure**, **disruption**, **modification,** or **destruction**.
- **Each organization** defines its own security policies for all its information systems.
- Information security is achieved by implementing managerial, operational, and technical controls that deliver information confidentiality, information integrity, and information availability.

INTRODUCTION TO INFORMATION SECURITY

- We can protect an information system by providing:
  - Personnel security to protect people
  - Procedural security to protect activities
  - Information security to protect data resources
  - Software and hardware security to protect technology
  - Network security to protect networks

INTRODUCTION TO INFORMATION SECURITY

- Employees can be a source of insecurity.
  - Some of them may unintentionally harm the system by making mistakes.
  - Some will maliciously compromise the system.
- We need personnel security, which are practices and tools adopted by the human resources and IT units to ensure that personnel security safeguards are applied.
- Personnel security safeguards is organized into:
  - Qualification assurance: people is hired if they match both job qualification and security clearance.
  - Screening assurance: screened to make sure history of poor behavior cannot infiltrate into the system, depending on the sensitivity and confidentiality of information.

INTRODUCTION TO INFORMATION SECURITY

- Personnel security safeguards is organized into:
  - Authorizing of process: granting or taking away any physical or system access privileges at the time of hiring of an employee or at the termination of his duties.
  - Security training: make it available to employees in accordance with the security requirements of their position.
  - Nondisclosure agreements: all employees have to sign nondisclosure agreements appropriate to their positions prior to granting access to that information.

INTRODUCTION TO INFORMATION SECURITY

- Procedural security to protect activities
  - Activities of an information system consist of all procedures, regulations, policies, standards, and protocols governing all interactions between all the components of the information system, and between these components and the information system and its environment.
  - Any weakness in any activity of the information system can produce undesired events that can compromise the security of the information system.
  - Any corruption in those activities can damage the information system in unpredictable ways.

INTRODUCTION TO INFORMATION SECURITY

- Information security to protect data resources
  - Data is understood as all the facts that are processed into information.
  - Information describes the meanings and interpretations that users associate with those facts.
  - Define all the conceptual resources that can be transformed into information of great value for the business
  - Conceptual resources we identified earlier are now part of the computing environment and have to be adequately secured.
  - Conceptual resources are physically secured to prevent unauthorized disclosure or unauthorized modification of their content as well as destruction of information technology resources.
  - Conceptual resources, such as programs, data, and information, can be secured by requiring users to supply passwords and digital certificates.
  - We can employ digital certificates and biometric techniques to authenticate the user and control access to information resources.

INTRODUCTION TO INFORMATION SECURITY

- Software and hardware security to protect technology
  - Software or hardware are both used to support enterprise operations and their security.
  - If one is compromised, then their functions will be compromised.
- Network security to protect networks
  - A network is any set of interconnected resources.
  - A computer network is simply a system of interconnected computers.
  - Network security aims at providing assurance that the network is performing critical security-related functions and has not been compromised in any way.
  - Servers on the network may contain useful data and information on how to access internal resources.

INTRODUCTION TO INFORMATION SECURITY

- Network security to protect networks
  - Workstations on the network may contain malicious data and can be used to attack other computers.
  - Routers, switches, bridges, hubs, and any other network equipment may be used as an access point to your network.
  - Your network wiring and media may be exploited by intruders to access your network or to initiate a wireless access point to your internal network.
  - You should also make sure that all laptops taken by company workers outside the company to conduct off-site work are reviewed for malicious content that can potentially harm the company when the laptops are connected to the internal network.
  - … etc.
- To ensure information security, all those components are interrelated.

INTRODUCTION TO INFORMATION SECURITY

- The general security goals organization or enterprise adopted are those constituting the CIA triad: **confidentiality, integrity, and availability**.
- The CIA triad suffers from some drawbacks:
  - Authentication: a mechanism designed to verify the identity of an agent, human, or system before access is granted.
  - Non-repudiation: it implies that both ends of a transmission cannot deny their involvement in this transmission. On Internet, digital signature may be used to enforce non-repudiation.
  - Risk management: a sequential process that starts with the identification of risks, then risk assessment and, finally, risk mitigation by selecting the appropriate security controls.

INTRODUCTION TO INFORMATION SECURITY

- Some of the steps needed to manage risks include the following:
  a. Identify and value assets in your computing environment.
  b. Assess asset vulnerabilities and their probabilities of being exploited.
  c. Assess threats and their probabilities of occurrence.
  d. Estimate each threat impact on each asset.
  e. Estimate basic risk, before adopting any security controls.
  f. Select the security controls that can reduce risks to acceptable levels.
  g. Mitigate risks by adopting the risk-driven security program devised in step (f).
  h. Evaluate the effectiveness of the risk-driven program to make sure it is reducing risks to acceptable levels..

INTRODUCTION TO INFORMATION SECURITY

- What is finally information security management? **Information security management** is a process that is capable of
  1. Accurately identifying an organization's computing environment, defining its criticality, and prioritizing its contributions to the organization's business-value-generation capabilities;
  2. Accurately identifying all security risks, assessing them, and then mitigating them by devising a comprehensive risk-driven security program;
  3. Providing for the continual improvement of the organization's risk position by automatically revising the risk-driven security program as security requirements change with changes in the computing environment.

INTRODUCTION TO INFORMATION SECURITY

- We can apply many security layers to further secure our business.
- The main idea is to use multiple barriers to make sure that if an intruder penetrates one layer, the next layer will hopefully prevent him or her from getting through.
- There are thousands of different attacks, and there are also thousands of ways we can counter such attacks.
- Usually, those attacks remain undetected and uncounted but there are many known countermeasures that can be deployed to secure the target assets
- We need security control to guarantee our business.

INTRODUCTION TO INFORMATION SECURITY

- Security controls: A risk-driven security program is usually written in terms of three different sets of security controls:
  - Managerial security controls: it focus on the management of the information system and the management of risk for a system. Managerial control are done in:
    - Risk assessment Planning
    - System and services acquisition
    - Certification, accreditation, and security assessments
  - Operational security controls: address security methods focusing on mechanisms primarily implemented and executed by people (as opposed to systems).

INTRODUCTION TO INFORMATION SECURITY

- Security controls: A risk-driven security program is usually written in terms of three different sets of security controls:
  - Operational security controls: address security methods focusing on mechanisms primarily implemented and executed by people (as opposed to systems). Operational control are in:
    - Personnel security
    - Physical and environmental protection
    - Contingency planning
    - Configuration management
    - Maintenance
    - System and information integrity
    - Media protection
    - Incident response

INTRODUCTION TO INFORMATION SECURITY

- Security controls: A risk-driven security program is usually written in terms of three different sets of security controls:
  - Technical security controls: focus on security controls that the computer system executes.
  - The controls can provide automated protection for unauthorized access or misuse, facilitate detection of security violations, and support security requirements for applications and data.
  - Technical controls use software and data to monitor and control access to information and computing systems. examples of technical controls:
    - Personnel security
    - Physical and environmental protection
    - Contingency planning
    - Configuration management

PLAN

- Information security management concepts
  - Selected management concepts
  - Required managerial skills
  - Strategic management concepts
  - IS security management activities
  - Information security (IS) management cycle
  - IS management cycle in relation with management concepts
  - Roles and responsibilities of an IS manager

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Management is a process that is used to accomplish organizational goals.
- Managers are the people who are in charge of achieving those goals.
- Managers perform the four main managerial functions that are agreed upon in most of the literature:
  - Planning: determining what to do in the future.
  - Organizing: allocate resources, assign tasks, evaluate the progress of achieving organizational goals.
  - Directing: supervising and leading workers to accomplish the goals of the organization.
  - Controlling: evaluating workers' performance in terms of how effectively those goals are being achieved.
- These managerial functions are performed throughout an organization independently of the type of service offered.

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Managers belong to different ranks depending on their positions in the organizational hierarchy
- Creativity is an important skill that is found in managers at a higher level, where more intelligent, more abstracted, and more valuable strategic information is needed.
- To be a computer-literate manager, you must be able to define information requirements effectively and have an understanding of decision support tools such as the Internet, database managers, report writers, spreadsheets, and financial planning systems.
- The information-literate security manager will know how to effectively and efficiently access the information needed to evaluate any business disruptions detected.

INFORMATION SECURITY MANAGEMENT CONCEPTS

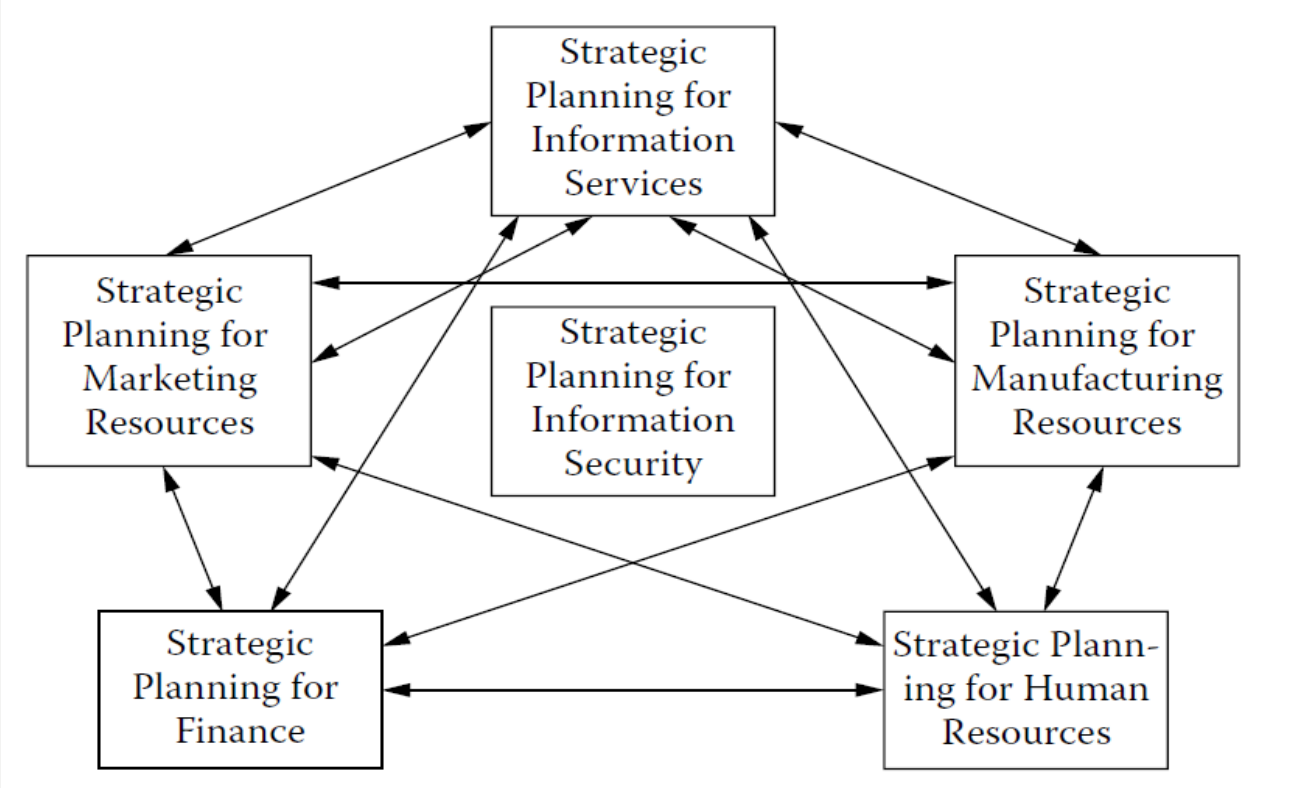
- IT security literacy refers to an individual's ability to apply security basics needed to protect electronic information and systems.
- Managerial skills
  - Technical skill: give the ability to handle the technical side of the assigned task
  - Human skill: give the power to communicate effectively with your colleagues and employees
  - Creativity skill: involve the formulation of innovative ideas and concepts.
- In common organizational management roles, we have figurehead (for ceremonial duties), leader (hiring, training, motivation, encouragement) and liaison (to meet people outside the organization).

INFORMATION SECURITY MANAGEMENT CONCEPTS

- In Informational role:
  - Monitor: collects information and processes it for the purpose of identifying areas of low performance (challenge is information sensitivity)
  - Disseminator and Spokesperson: source of valuable information to others in his or her unit (sensitivity)
- At Decisional role
  - Entrepreneur: improves the structure of the unit in a permanent way for better efficiency.
  - Disturbance handler: to react to an unexpected event (reaction in conformity with the security policy)
  - Resource allocator: allocate available resources to people working on projects.

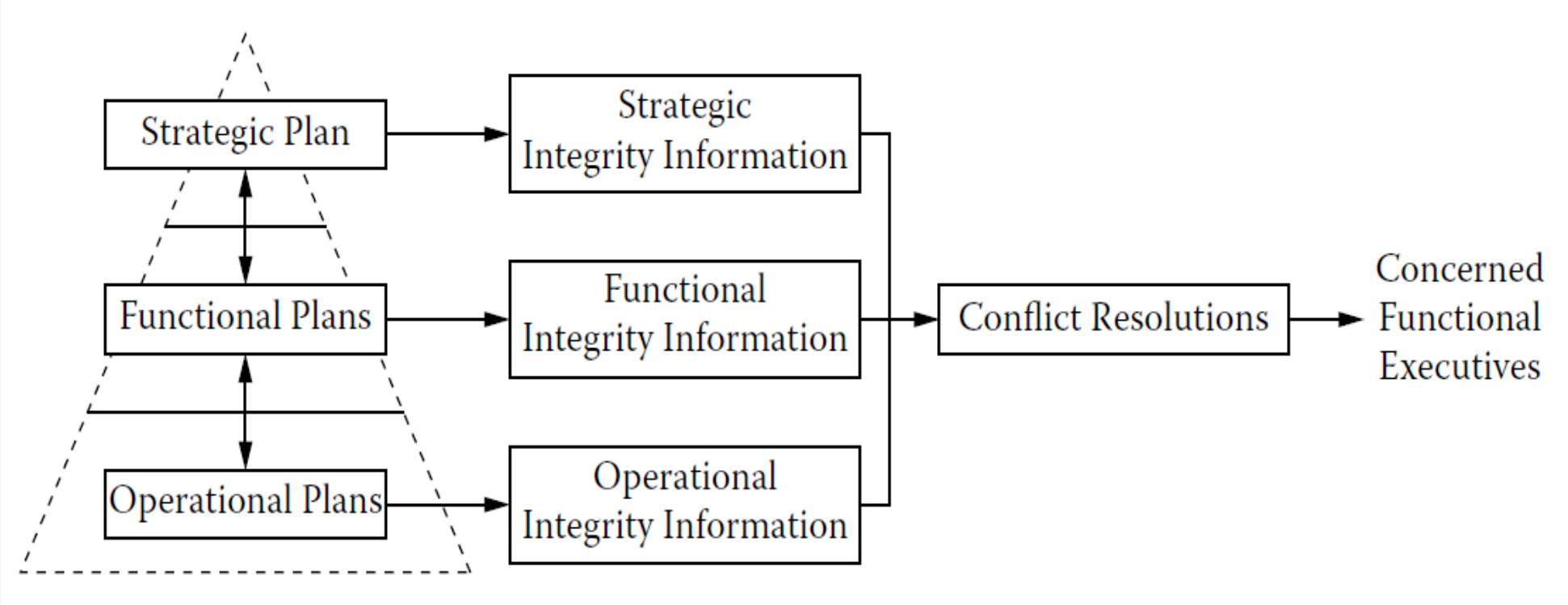
INFORMATION SECURITY MANAGEMENT CONCEPTS

- At Decisional role
  - Resource allocator: allocate available resources to people working on projects.
  - Negotiator: resolves conflicts within the unit or outside it.
- Strategic management concepts
  - Before the creation of an IS unit in the organization



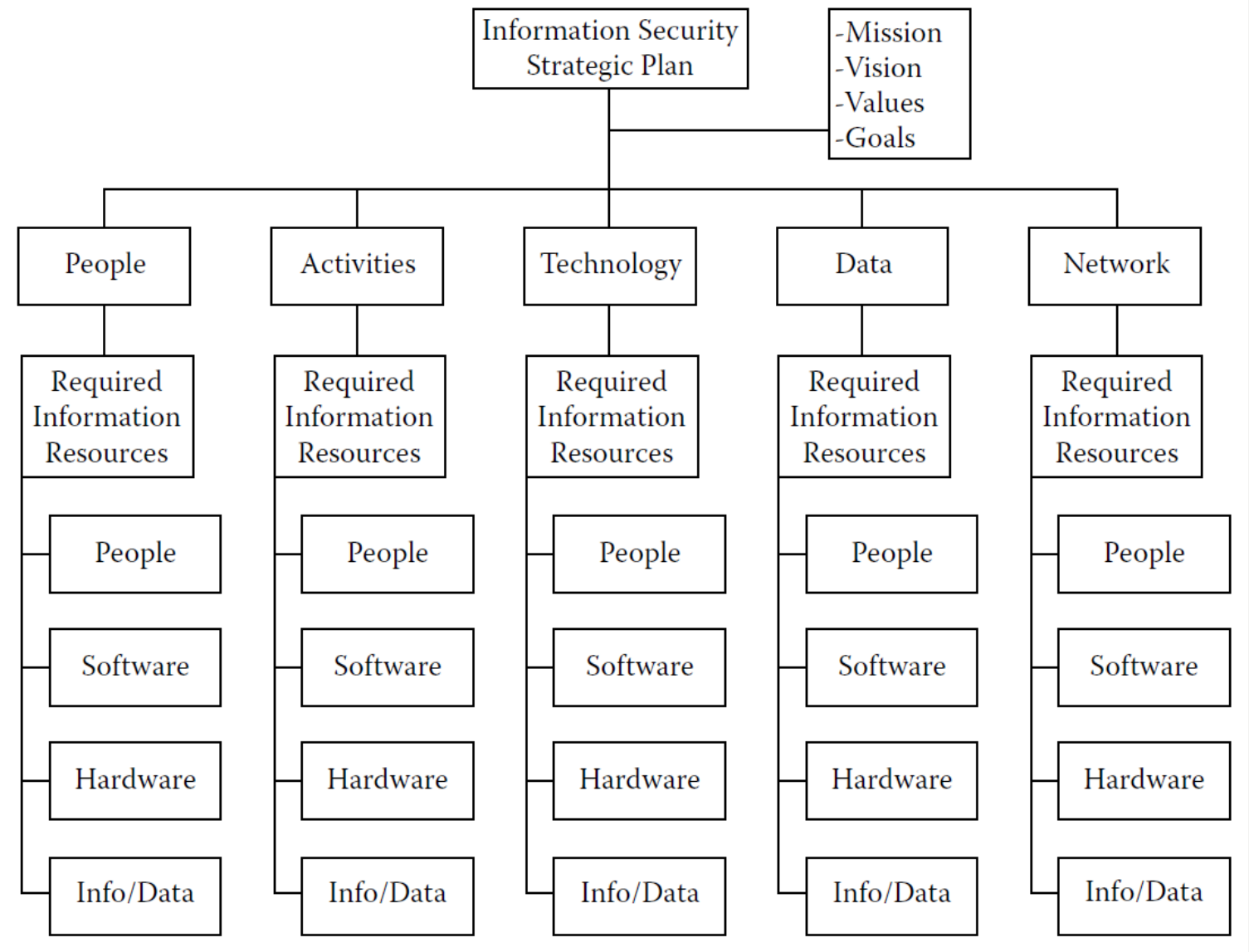
INFORMATION SECURITY MANAGEMENT CONCEPTS

- Strategic management concepts
  - When IS unit exist in an organization



INFORMATION SECURITY MANAGEMENT CONCEPTS

- Strategic management concepts
  - A generic information security strategic plan.



INFORMATION SECURITY MANAGEMENT CONCEPTS

- Strategic management concepts
  - There is no easy way to synchronize all the strategic managers, functional managers, and operational mangers involved in achieving their defined set of activities.
  - A strategic plan has no utility if its mission, vision, goals, and values cannot be transformed into outcomes valued by customers.
  - Customers will not see the strategic mission or values of the organization, but the outcomes from them.

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Information Systems (IS) Security management activities.
  - Information security management is a continuous process.
  - There are prerequisites for it to start, phases to be accomplished, and recursive continual improvement processes that restart the information security management cycle.
  - Prerequisites:
    - You need to have a computing environment with known resources,
    - A corporate security policy, a known business mission, and known strategic goals.
    - All company assets have to identified, classified on information sensitivity, and valued.
    - The inventory of company assets is a live database, so information on assets is continuously revised.

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Information Systems (IS) Security management activities.
  - Core Phases IS security management:
    1. Security planning
    2. Development and revision of security policy
    3. Security risk analysis
    4. Security assessment (passive or active)
    5. Security auditing
    6. Security certification and accreditation
    7. Development of an information security management system (ISMS)
    8. Intrusion detection

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Security planning
  - It complements the IT plan
  - It defines the security requirements for the organization's computing environment and its components.
  - It produces an inventory of all information resources and their security requirements.
  - The security plan recommends a set of managerial, operational, and technical security controls that the organization will need for the next 3 years.
- Development and Revision of Security Policy
  - The corporate security of the organization is determined by the acceptable behavior of its computing environment.
  - The business environment of an organization changes, and its computing environment.
  - The review of security policies is a serious project.

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Security Risk Analysis
  - It is needed before recommending any security controls.
  - In this activity, security risks are identified, assessed, and mitigated based on information about the assets, the threats, and available security controls.
- Security Assessment (Passive or Active)
  - The security assessment task may be completed in a passive way or in an active way.
  - In a passive security assessment task, the testing is conducted without penetration of the system.
  - In an active security assessment task, however, selected systems are penetrated as real hackers do.

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Security Auditing
  - A security audit may be conducted by internal agents.
  - It is usually initiated to review the organization for any security weaknesses,
  - If found, security controls are recommended.
- Security Certification and Accreditation
  - The organization may request an external audit to comply with a given security standard.
  - In case of compliance, the organization will be certified against that standard.

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Development of ISMS
  - The ISMS defines a risk-driven security program for the organization.
  - This activity is performed after defining a scope and a security policy for the scoped system.
  - An ISMS is developed based on standards (ISO 27001 for example).
- Intrusion Detection
  - It is a very important step in information security management.
  - Log information about incidents is useful in understanding the changes in the system.
  - Reports about intrusions in the computing environment are needed to estimate the frequency of threats, and their impact.
  - It is vital to monitor the computing environment and detect intrusions before attacks occur. Recovery decisions and corrective actions are planned based on reports generated by intrusion detection systems.

INFORMATION SECURITY MANAGEMENT CONCEPTS

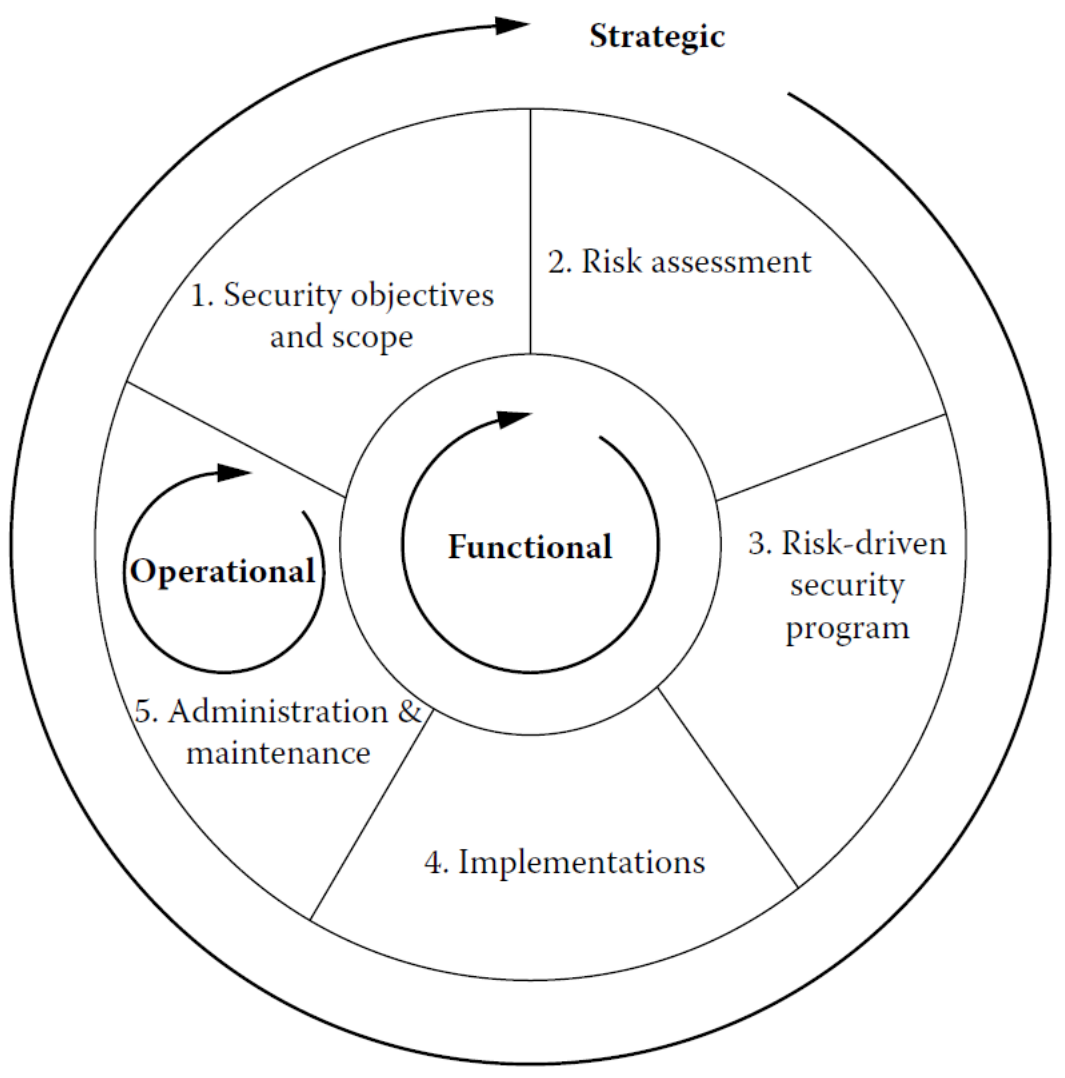
- Information security management produces an ISMS with a statement of applicability, or a risk-driven security program.
- A thorough review of current risks is needed to ensure that risks are still below their accepted levels.
- The vulnerability of assets may change; the threats may change; company resources may change, including people, activities, data, technology, and networks.
- Any of those changes may lead to changes in current risks.
- The recursive continual security improvement task will restart the information security management process.

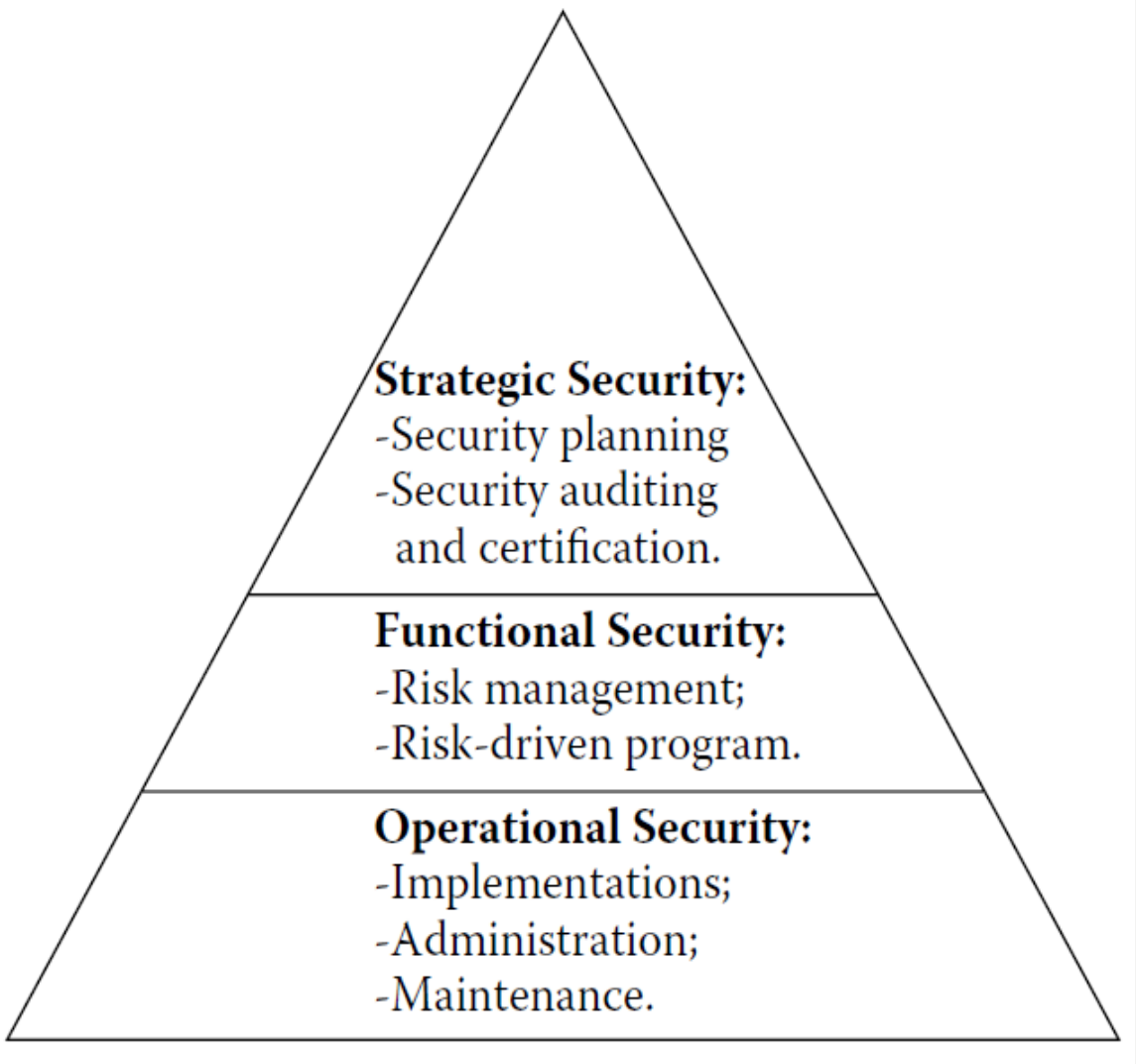
INFORMATION SECURITY MANAGEMENT CONCEPTS

- Information security management cycle
- The main security goals are set to
  1. Mitigate security risks until they go lower than or equal to their accepted levels as set in the corporate security policy, and
  2. Maintain a continual security improvement cycle so that when changes occur in the computing environment the current risk-driven security program is reviewed to adjust to any changes that lead to increased security risks.
- The information security management cycle involves all levels of information security management: strategic security management, functional security management, and operational security management.

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Information security management cycle and his pyramid





INFORMATION SECURITY MANAGEMENT CONCEPTS

- Information security management cycle and his pyramid
- The security manager, at the security **operational** level, has to monitor the interactions between assets and the security program.
- If the security risk of an asset goes beyond its accepted risk level, then the security controls added to the security program to protect this asset have to be revised.
- Information security **controls** are any security activities designed to reduce security risks, including security policies, practices, procedures, or mechanisms.
- Information security **requirements** define the states of information resources that business owners accept as sufficient to fulfill the business mission set for the organization.

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Security managers are responsible for assessment, security planning, and maintenance of effective security requirements within the organization.
- Security managers hold a senior management rank, they are responsibility is to develop security management programs.
- At the operational level, the security administrator
  - Deploys and configures security solutions
  - Maintains the delivery of security solutions
  - Monitors the computing environment
  - Evaluates potential security problems that may occur on a system
  - Reports on security matters to security managers and information and system owners

INFORMATION SECURITY MANAGEMENT CONCEPTS

- The strategic information manager cannot develop a good strategic plan without having good and SMART strategic goals.
- Here are the main questions that information security managers have to answer:
  - Do you know the organization?
  - Do you know your strategic thinking?
  - Do you know the corporate security policy?
  - Do you know your security training programs?

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Roles and responsibilities of an IS manager
  - Network administers
  - Information security analysts
  - Incident response staff
  - Forensic staff
  - Security technicians/operators
- As shown in the pyramid before, we can have another appellation.
  - Strategic security management: This level of security management is concerned with strategic management. The main activities initiated at this level include security planning, security auditing and certification. A generic name for any responsible at this level is **strategic information security manager**

INFORMATION SECURITY MANAGEMENT CONCEPTS

- As shown in the pyramid before, we can have another appellation.
  - Functional security management: this level of security management is concerned with functional management in information security. Activities at the functional level include risk management and security design. A generic name for any responsible at this level is **functional information security manager**
  - Operational security management: this level of security management is concerned with operational management in information security. Activities at the functional level include security implementation, security administration, and security maintenance. A generic name for any responsible at this level is **operational information security manager**

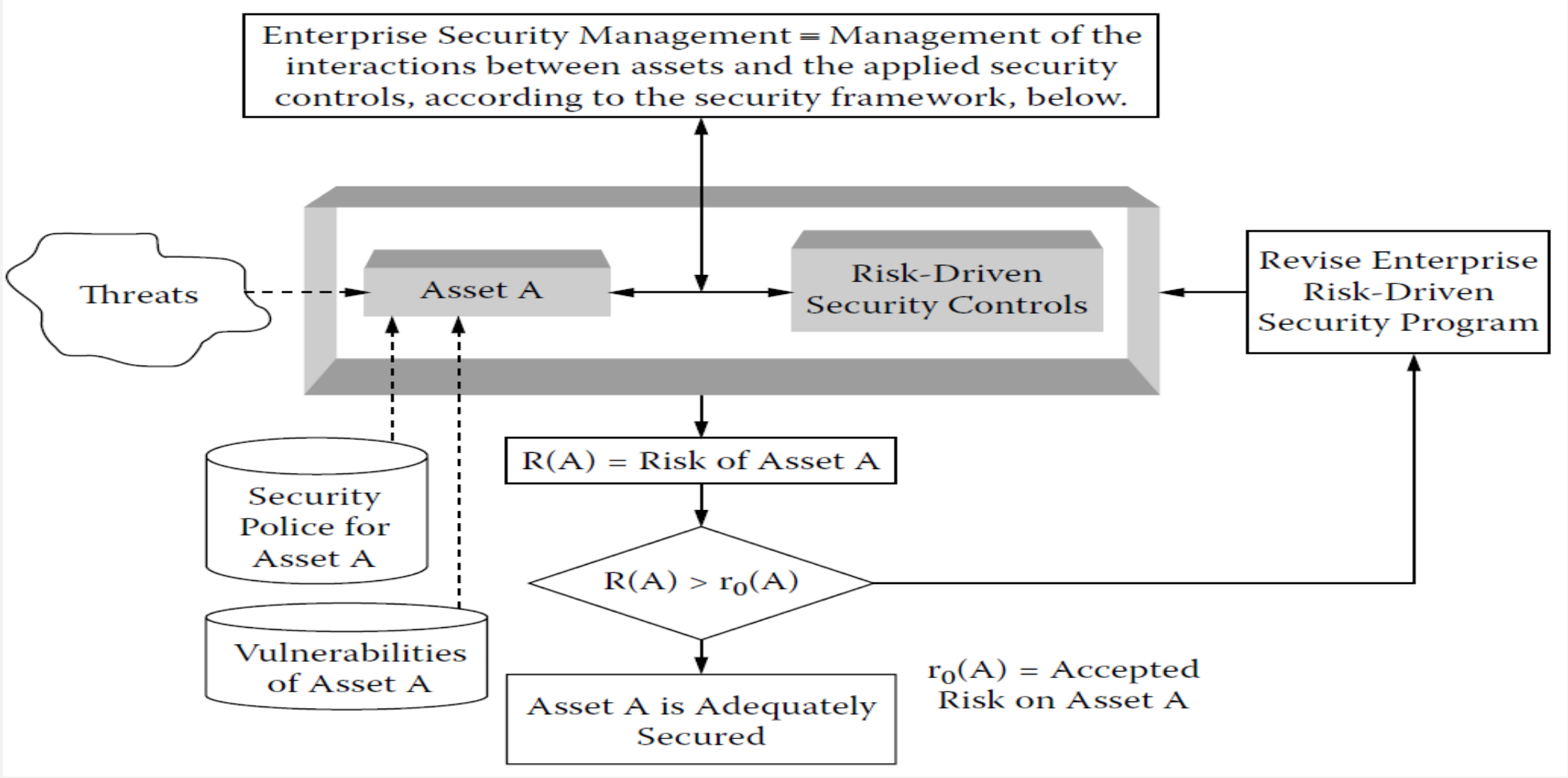
INFORMATION SECURITY MANAGEMENT CONCEPTS

- Example of active interactions among the assets and the security controls.
  - Asset A is affected by existing threats that can at any time exploit asset vulnerabilities to compromise the security of the asset.
  - The asset controls included in the risk-driven security program to protect Asset A continue to struggle to protect the asset.
  - Hence, there are many interactions between the asset and its security controls to protect the asset.
  - When the asset security policy is violated, causing an increase in the asset risk above its accepted risk level, then the risk-driven security program has to be revised to enhance security by implementing new security controls.

INFORMATION SECURITY MANAGEMENT CONCEPTS

- Example of active interactions among the assets and the security controls.
  - Those interactions involve the asset itself and the security controls:
  - Asset: The asset is classified and valued; its accepted risk level is defined, and it is protected to achieve its business mission
  - Security controls: Those security controls, part of the risk-driven security program, act on the asset to ensure that its security policy is enforced, and its security requirements are defined, implemented, measured, and controlled.
- All this is resume in the next slide.

INFORMATION SECURITY MANAGEMENT CONCEPTS

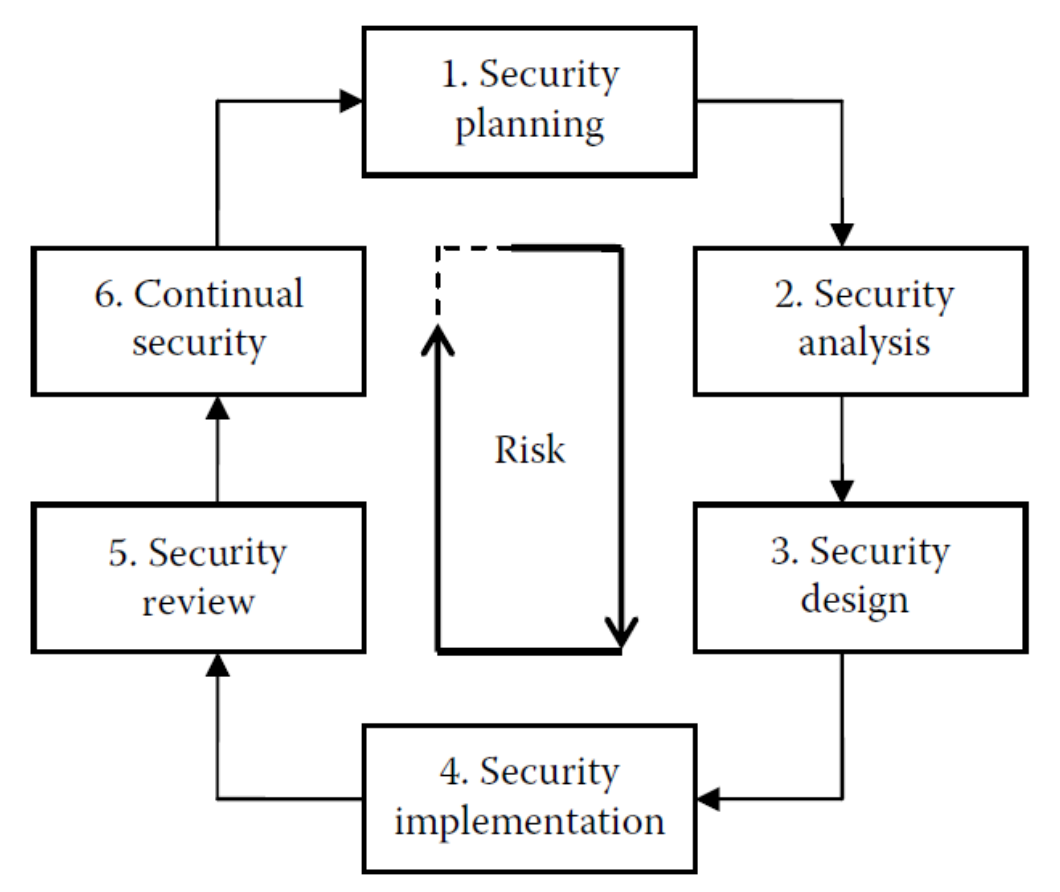


PLAN

- Information security life cycle
  - What is security life cycle (SLC)
  - How a security life cycle is planned
  - How security is analyzed in the security life cycle
  - How to conduct an impact analysis
  - How to compute asset exposures to threats
  - How to conduct a risk analysis
  - How to design security in the security life cycle
  - How to mitigate security risks
  - How to review security in the security life cycle

INFORMATION SECURITY LIFE CYCLE

- The security life cycle describes all the steps necessary to achieve confidentiality, integrity, and availability for a given information asset in an organization.
- The security objectives are written in accordance with its current security policy.



INFORMATION SECURITY LIFE CYCLE

- The security is initially planned
  - Asset security policy, its scope, its security objectives, a limited preliminary impact analysis, and a limited risk assessment analysis.
- Security analysis
  - Asset is analyzed to define its security requirements.
  - The security requirements are established based on information about the levels of impact the asset has on the business mission of the organization and based on information generated by a thorough assessment of risks that is sufficient for understanding of real security needs of the asset.
  - Security analysis often acquires information on current threats, current security controls, and asset vulnerabilities and their exposure.
- Security design
  - It will conduct a more detailed risk assessment to obtain further information on the design of a feasible risk-driven security program.
  - the design of the risk-driven security program is then ready for implementation.

INFORMATION SECURITY LIFE CYCLE

- The security review process starts after design and implementation.
  - It consists of the certification, accreditation and authorization of the security program.
- The security audit may take place in a periodic manner, after security review.
- Continual improvement is the final process in the security life cycle, where the security of the information asset is continuously monitored.
- If risks change, then corrective actions have to be taken to restore the security of the asset to its accepted state, as prescribed in its security policy.
- However, the security objectives, security policy, and computing environment all change, which will necessitate a new scope for the security of the asset.
- Initiate a new iteration of the security life cycle of the target information asset.

INFORMATION SECURITY LIFE CYCLE

- Security Planning
  - It is the foundation on which the development of a security program rests. It should not be skipped
  - It should be initiated and approved by the organization's upper management, satisfy the corporate security policy, and constantly remain aligned with the organizational strategic plan.
- How the security of the information asset is planned:
  - Asset definition
  - Security policy
  - Security objectives
  - Security scope

INFORMATION SECURITY LIFE CYCLE

- Asset definition
  - The identification and definition of assets is the first step in any security analysis.
  - We need to identify the information asset for which an approved budget is made available for its protection.
  - Initial identification of the information assets can be problem-based approach and objective based approach.
    - In a problem-based approach, an information asset may be identified as a candidate for a security project if this asset has been involved in an undesired incident that has been blamed for compromising one of the security objectives of the organization or one of its information systems: confidentiality, integrity, or availability.
    - The objective-based approach for asset identification is based on upper management or executive directives. A security project is then initiated for any information asset that is part of an executive directive. The only restrictions are the ones entailed by the asset security policy, its risk position, its prescribed budget, or its feasibility study results.

INFORMATION SECURITY LIFE CYCLE

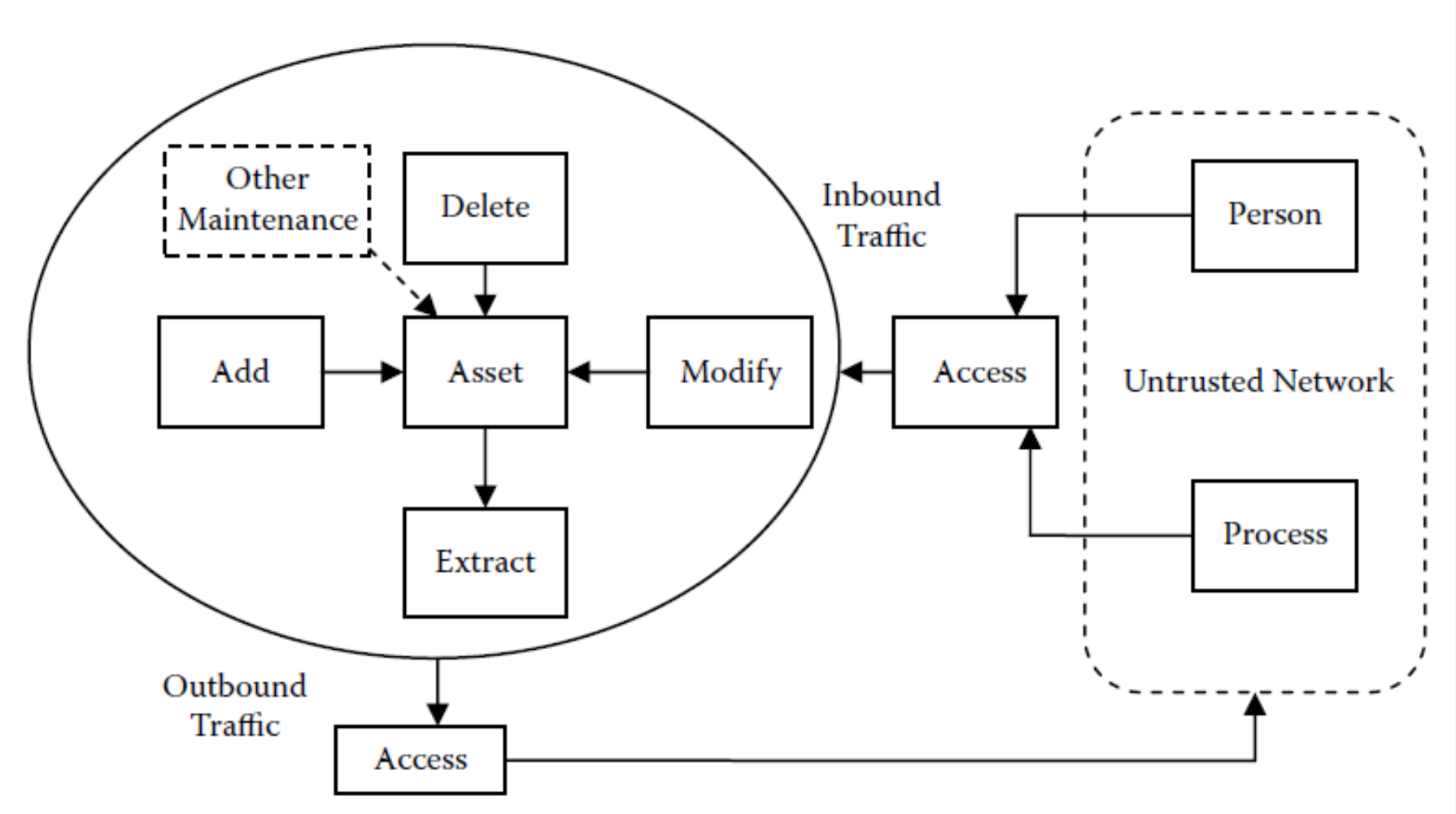
- Asset definition
  - The asset owner is the person who knows the business value of the information asset.
  - The asset owner will be in charge of asset valuation and all asset operations once this asset has been authorized.
  - The asset valuation will determine the business-value-generation capability of this asset, based on which the security requirements are defined.

INFORMATION SECURITY LIFE CYCLE

- Security policy
  - The security policy of an information asset is its acceptable computing behavior.
  - The security policy should define the acceptable asset interactions with the rest of the components in the computing environment.
  - Any violation of the acceptable computing behavior of an information asset undermines its business-value-generation capability.
  - The security of the information asset can therefore only be achieved with strict enforcement of its security policy.
  - If an unauthorized user succeeds in accessing the information asset, its security will be compromised.
  - The security of the information asset will also be compromised if an authorized user accesses the information asset and performs an unauthorized activity.

INFORMATION SECURITY LIFE CYCLE

- Security policy



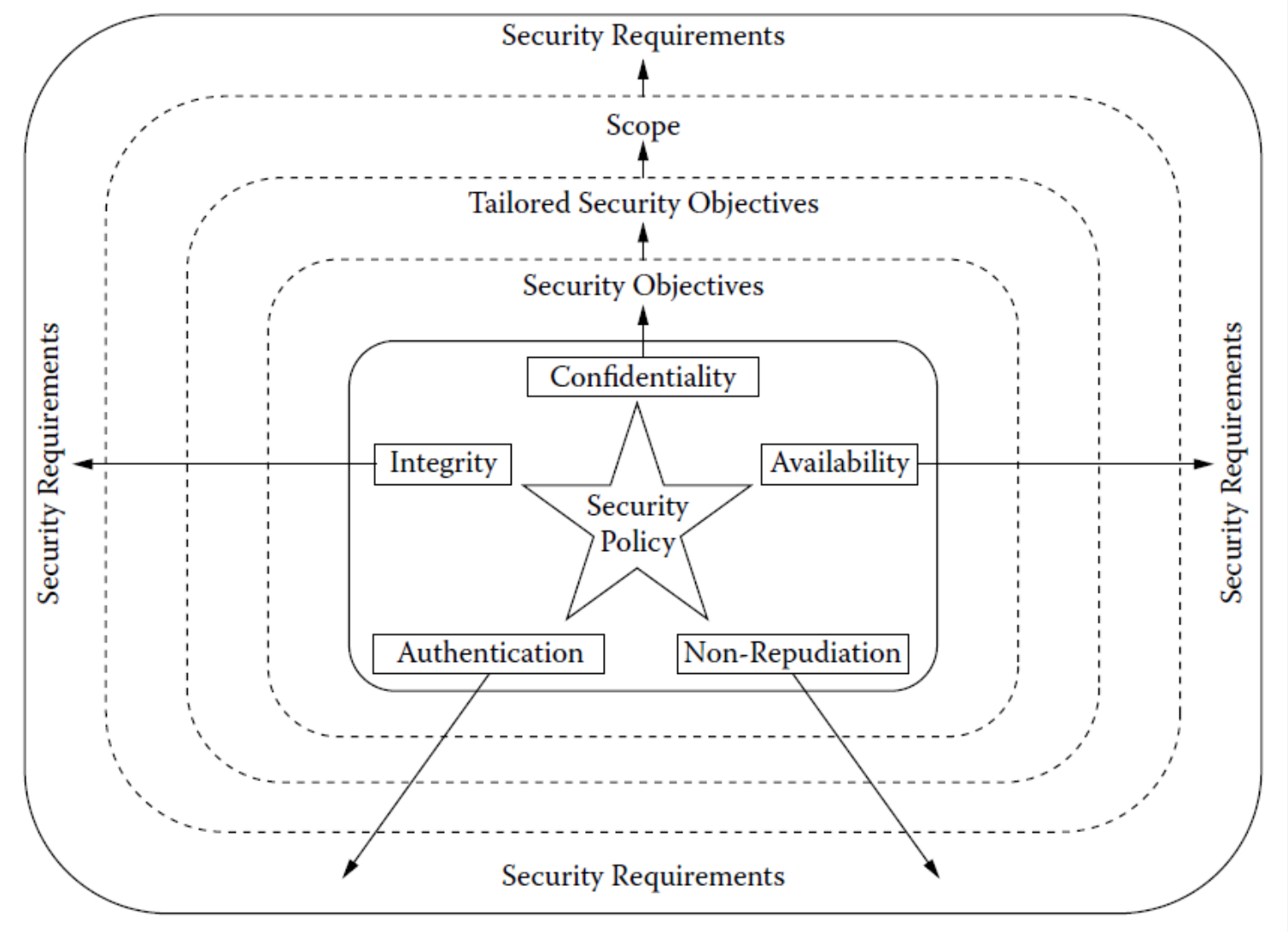
Computing behavior of an asset expressed in its security policy

INFORMATION SECURITY LIFE CYCLE

- Security objectives
  - The most common security objectives set for the security of an information asset are confidentiality, integrity, availability, authentication, and non-repudiation.
  - These security objectives may be tailored to the security policy of the information asset in question.
    - Example: how and under what conditions should non-repudiation be verified in order to achieve the business goal set for an information asset?
  - The security requirements for an information asset also depend on its security objectives.
  - These requirements will obviously change if we drop an old security objective, add a new one, or modify an existing one.
  - Any incompleteness or ambiguity in their definition will translate into deficient security requirements that will lead to inadequate security for the target information asset.

INFORMATION SECURITY LIFE CYCLE

- Security objectives
  - Objectives of information asset

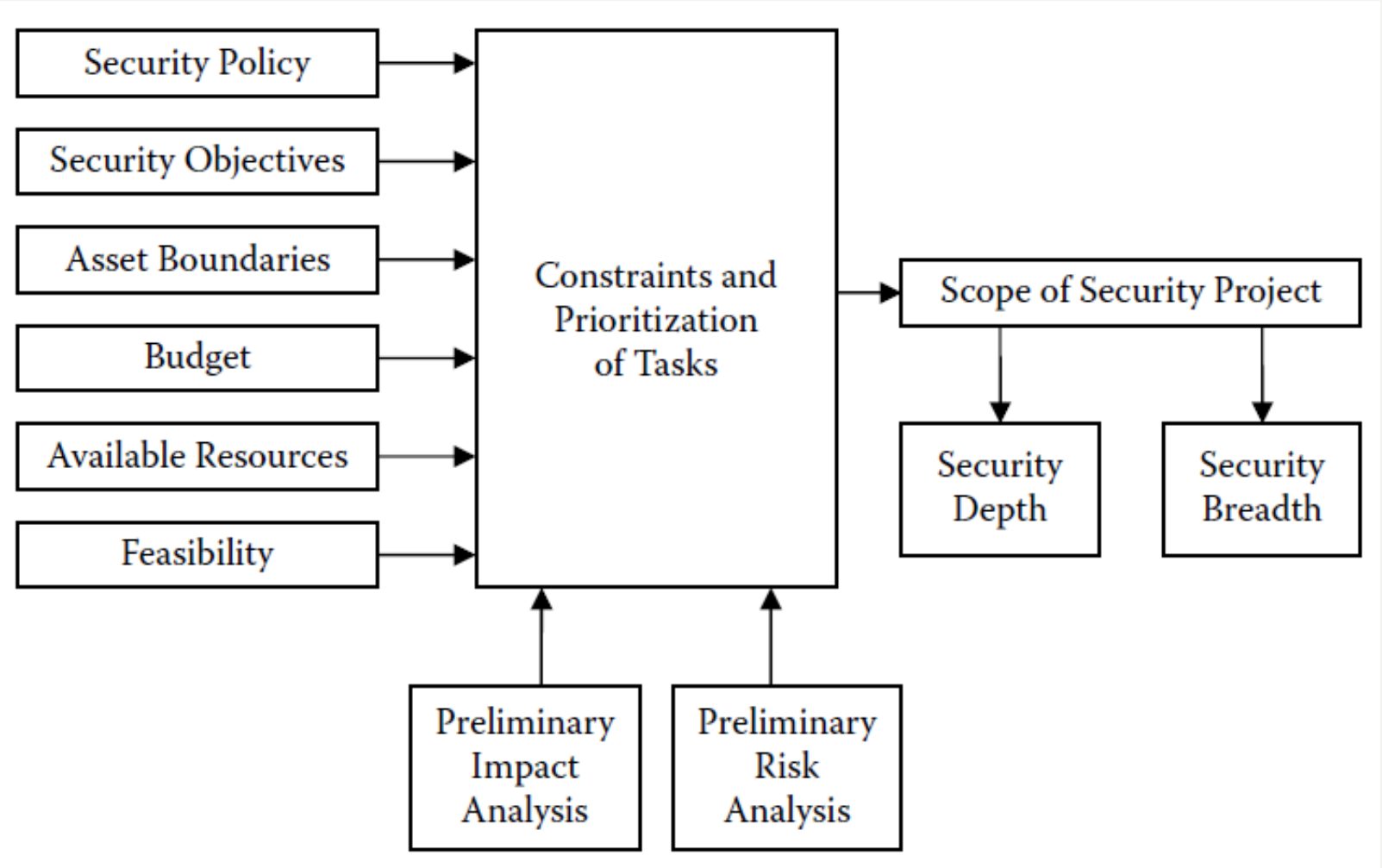


INFORMATION SECURITY LIFE CYCLE

- Security scope
  - The scope of the asset security project defines the security depth and breadth of the project.
  - Not all security requirements can be met, but enough should be satisfied to establish the acceptable security risk level established by the asset security policy.
  - The scope defines the depth of the security design and the breath of the security requirements that must be addressed to achieve the security objectives set for the information asset.
  - There are also additional constraints that influence the definition of the scope of the security project for an information asset: budget constraints and any feasibility conditions established by the project feasibility study.

INFORMATION SECURITY LIFE CYCLE

- Security scope



INFORMATION SECURITY LIFE CYCLE

- Security scope
  - The preliminary impact analysis indicates the level of impact the target information asset has on the organization's business mission.
    - If the impact is low, then the asset is of low criticality.
    - If this impact is moderate, then the criticality level of the asset is moderate.
    - If this impact is high, then the asset is highly critical.
  - Preliminary risk assessment only produces a brief initial description of the basic security needs of the information asset, enough to guide the definition of the security scope of the project.

INFORMATION SECURITY LIFE CYCLE

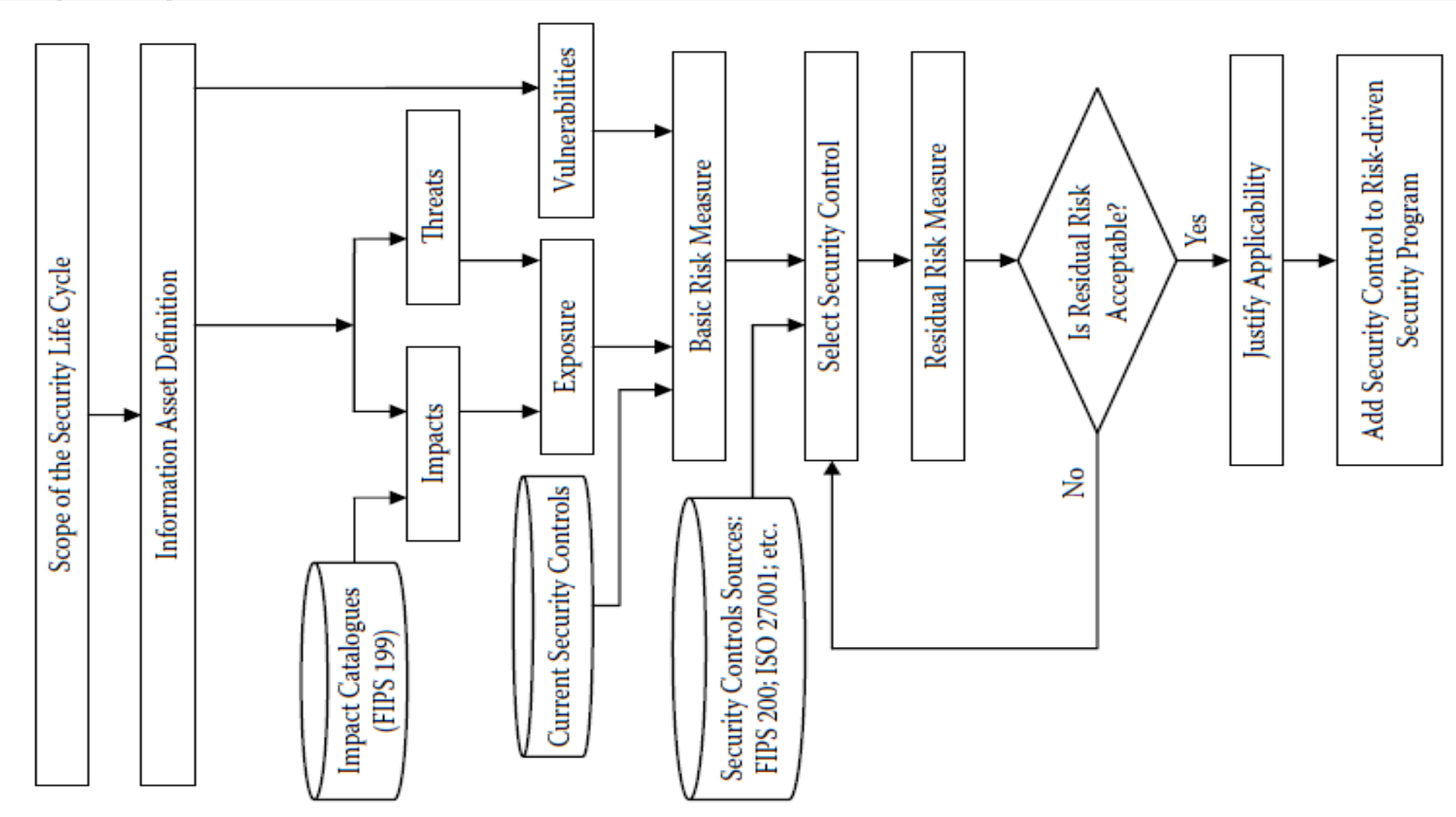
- The need for information security is expressed in terms of the need for confidentiality, integrity, availability, authentication, and non-repudiation.
- A preliminary risk assessment defines the threat environment in which the target information asset operates.
- This risk assessment activity will guide the security planning team in defining a scope that is sufficient to provide for the protection of the information asset in its intended operational environment.

INFORMATION SECURITY LIFE CYCLE

- Security analysis
  - The objective of security analysis in a security life cycle is to define the security requirements needed to adequately protect the target information asset.
  - The security requirements should reflect the results of risk assessment in terms of risks to the confidentiality, integrity, and availability of the system and its information.
- The security analysis of an information asset often basically starts with simple questions such as,
  - Why is security needed for this asset?
  - What are the valuable components of the information asset that require protection?
  - What are the threats to the target information asset?
  - How is this asset vulnerable?
  - What are the risks or threats that can cause harm to the asset, considering the asset vulnerabilities and the resulting impacts of the damage?
  - What are the acceptable risks for the information asset?

INFORMATION SECURITY LIFE CYCLE

- Security analysis



INFORMATION SECURITY LIFE CYCLE

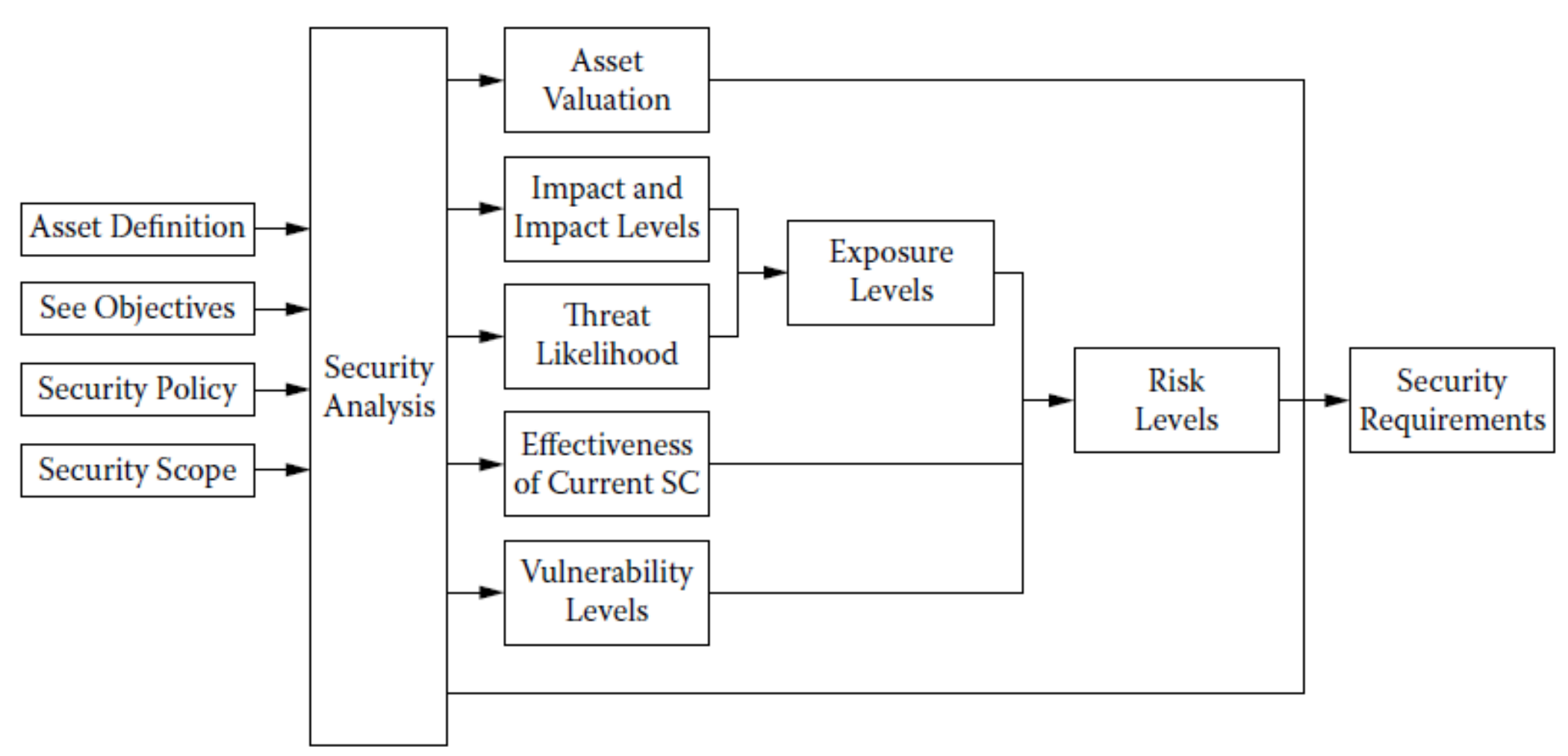
- Security analysis
  - Any security analysis methodology adopted by an organization should include at least the following activities:
    - Asset analysis: The asset has to be studied in terms of its acquisition cost, operating cost, maintenance cost, its benefits, and its contribution in generating the business value of the enterprise.
    - Impact analysis: Estimating potential harm that might be inflicted on the asset as well as resulting impacts for the organization.
    - Threat analysis: Identifying and defining threats to the target information asset and estimating their likelihood of occurrence.
    - Exposure analysis: Independently of its vulnerabilities, the asset may be exposed in such a way that if the threat materializes the worst of the possible impact levels may be realized.

INFORMATION SECURITY LIFE CYCLE

- Security analysis
  - Any security analysis methodology adopted by an organization should include at least the following activities:
    - Vulnerability analysis: Analyzing asset vulnerabilities and estimating asset exposure levels.
    - Analysis of current security controls: Estimating the effectiveness of the current security controls.
    - Risk analysis: Measuring the risks using exposure rating, asset vulnerabilities, and the effectiveness of current security controls.
    - Security requirements: Defining the security requirements to use in designing the security of the information asset.

INFORMATION SECURITY LIFE CYCLE

- Security analysis output



INFORMATION SECURITY LIFE CYCLE

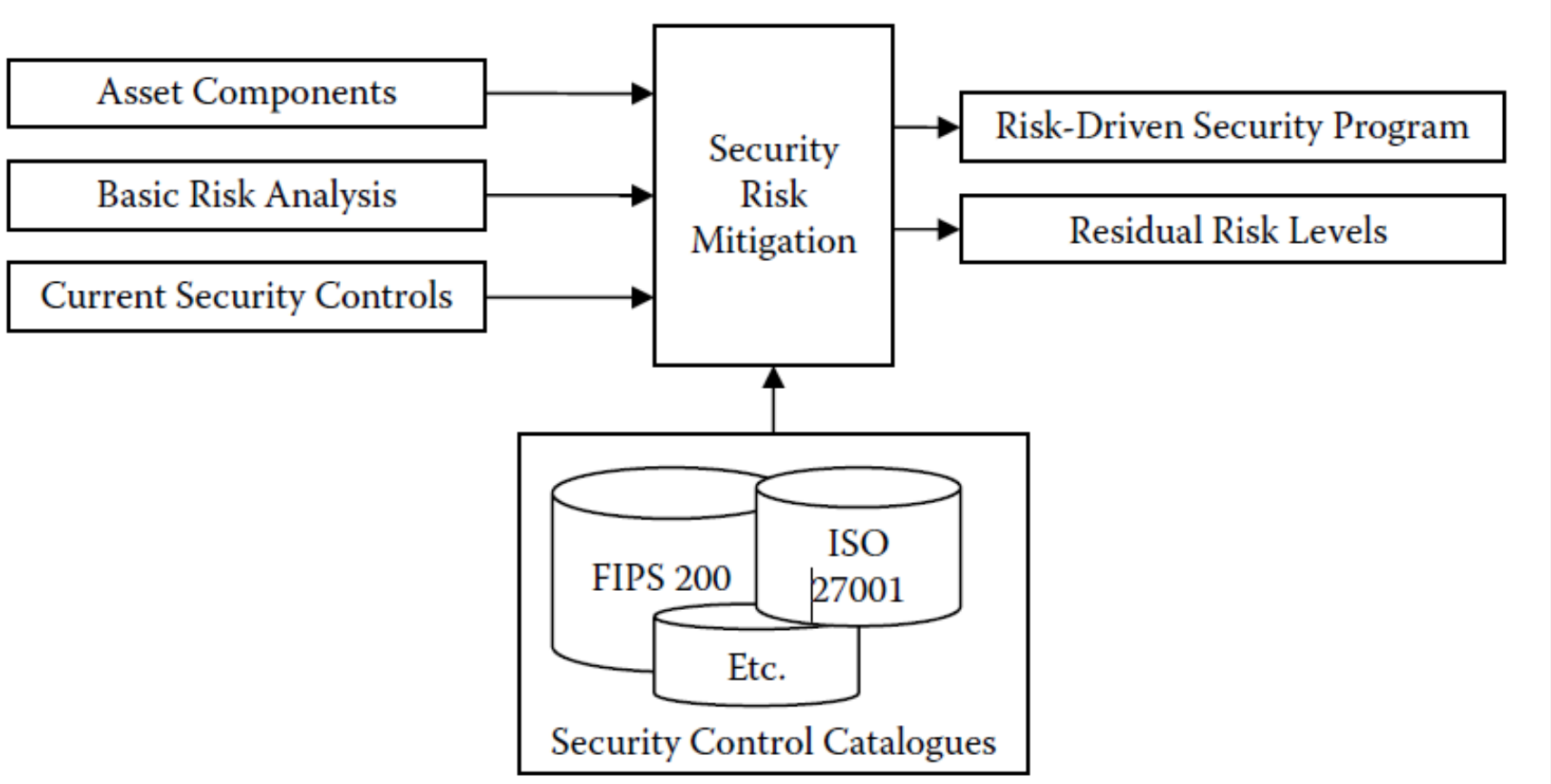
- Security Design
  - It aims at devising security to meet the security objectives defined for the target information asset.
  - The security design activity will therefore consist of five security design tasks:
    1. .Security design for confidentiality
    2. Security design for integrity
    3. Security design for availability
    4. Security design for authentication
    5. Security design for non-repudiation
  - Where do we find security controls that can ensure confidentiality, integrity, availability, authentication, and non-repudiation?
    - The answer to this question is always linked to security risk mitigation

INFORMATION SECURITY LIFE CYCLE

- Security Design
  - The security design phase consists of the following steps:
    - Risk mitigation: The risk mitigation process aims at reducing the security of the asset to its acceptable risk level as specified in its security policy.
    - Design of security training programs: The appropriate security training program should be designed for members of the security maintenance team. The contents of this training program will depend on the definition of the information asset in question and its security policy.
    - Design of security planning programs: Security planning consists of mainly two aspects: - the design of a security plan that defines security requirements of information for the next 3 years, and the design of a business continuity plan that defines the actions to be taken to continue business operations when a disaster takes place.
    - Design of the risk-driven security program

INFORMATION SECURITY LIFE CYCLE

- Security Design
  - The security design phase consists of the following steps:
    - Design of the risk-driven security program:



INFORMATION SECURITY LIFE CYCLE

- Security Implementation
  - It consists of the implementation of the risk-driven security program.
  - The implementation step must ensure both usability and sustainability of the security program.
  - This may be substantiated by some design verification activities.
  - Those activities constitute a testing period, during which the security program's usability and sustainability will be inspected.
  - The security implementation team may elect to discontinue the process if the security-tested mechanism was found incomplete or vulnerable.
  - Both usability and sustainability are two goals to be incorporated in any security design.
  - While the security implementation team will make any possible effort to hide any added complexity due to embedded security controls, it is imperative that all configurations applied on the target information asset yield to adequate security implementation as specified in the asset security policy.

INFORMATION SECURITY LIFE CYCLE

- Security Review
  - Its purpose is to ensure that the authorizing official and the asset owner agree on the proposed security program, including the asset's documented security requirements, before the certification agent begins the assessment of the security controls in the information asset.
  - It consists of two main steps:
    1. Security review for authorization
    2. Security auditing
  - To ensure that the authorizing official and the asset owner agree on the proposed security program.
  - Done before the certification agent begins the assessment of the security controls in the information asset.
  - The security certification phase aims at determining the extent to which the security controls in the information asset are implemented correctly, operating as intended, and producing the desired outcomes.

INFORMATION SECURITY LIFE CYCLE

- Continual service
  - It consists of continuous monitoring activities
  - It is intended to ensure that security risks stay at accepted levels and that if the effectiveness of current security controls diminish and cause the accepted risk levels to be violated, corrective actions are planned to bring the risk levels back to their accepted levels.
  - The following steps are usually planned to achieve continual security:
    1. Configuration management and control
    2. Monitoring of security controls
    3. Monitoring of the computing environment for any changes
    4. Reporting of changes and documentation
  - The activities in this phase are performed continuously throughout the security life cycle of the information asset.

INFORMATION SECURITY LIFE CYCLE

- Continual service
  - The continual security phase may include the following activities:
    - Periodic assessments of risk
    - Periodic review of policies and procedures
    - Security awareness training
    - Periodic testing and evaluation of the effectiveness of information security policies, procedures, practices, and security controls to be periodically performed.
    - A process for planning, implementing, evaluating, and documenting remedial actions to address any deficiencies in the information security policies, procedures, and practices of the agency.
    - Procedures for detecting, reporting, and responding to security incidents

INFORMATION SECURITY LIFE CYCLE

- **Class Workshop**

  Consider a small business that has established an online presence using its Web site. Assume that the business hosts its own Web site. Follow all the steps of the security life cycle, treating the small business Web site as the target information asset. Also assume that the enterprise has a current security plan and current business continuity plan.

INFORMATION SECURITY LIFE CYCLE

- **Homework**

  A computing environment consists of people, activities, data, technology, and network. Apply the information security life cycle to ensure the security of the

  computing environment.

  Draw a 5 × 6 matrix with the computing environment components on the columns and the security life cycle phases on the rows. In each cell, show the types of security objectives that are most important among confidentiality, integrity, and availability.

PLAN

- Information security risk management
  - What security risk management is
  - How security risk management works
  - What strategic, functional, and operational risks are
  - How security risk is mitigated
  - How productivity, security compromise, and recovery work together

INFORMATION SECURITY RISK MANAGEMENT

- **Risk** is a measure of the potential inability to achieve overall project objectives within defined cost, schedule, and technical constraints.
- It has two components:
  - the probability/likelihood of failing to achieve a particular outcome,
  - the consequences/impacts of failing to achieve that outcome
- Events are elements in the computing environment that should be assessed to determine the level of risk.
- The events should be defined at a level where we can comprehend the potential impact and its causes.
- There are two components of risk: **probability** and **consequence/impact.**

INFORMATION SECURITY RISK MANAGEMENT

- Risk involves many components across assets, threats, vulnerabilities, and controls.
- Adopted security controls will apply to one or more layers of an organization's technical architecture.
  - **Physical security**: This refers to barrier placed around a computing system to deter unauthorized physical access to that computing system.
  - **Network security**: A well-designed and properly implemented network architecture provides highly available, secure, scalable, manageable, and reliable services.
  - **Application security**: essential to the security model, applications exist within the context of the overall system, so you should consider the security of the entire environment when evaluating application security.
  - **Data security**: data is the most valuable organizational resource because it produces organizational information. Data can be protected in different ways even though cryptography and backup remain the most popular methods of protection
- **Security risk management** consists of a set of recurrent and documented phases: risk planning, risk analysis, risk assessment, risk treatment, and risk monitoring.

INFORMATION SECURITY RISK MANAGEMENT

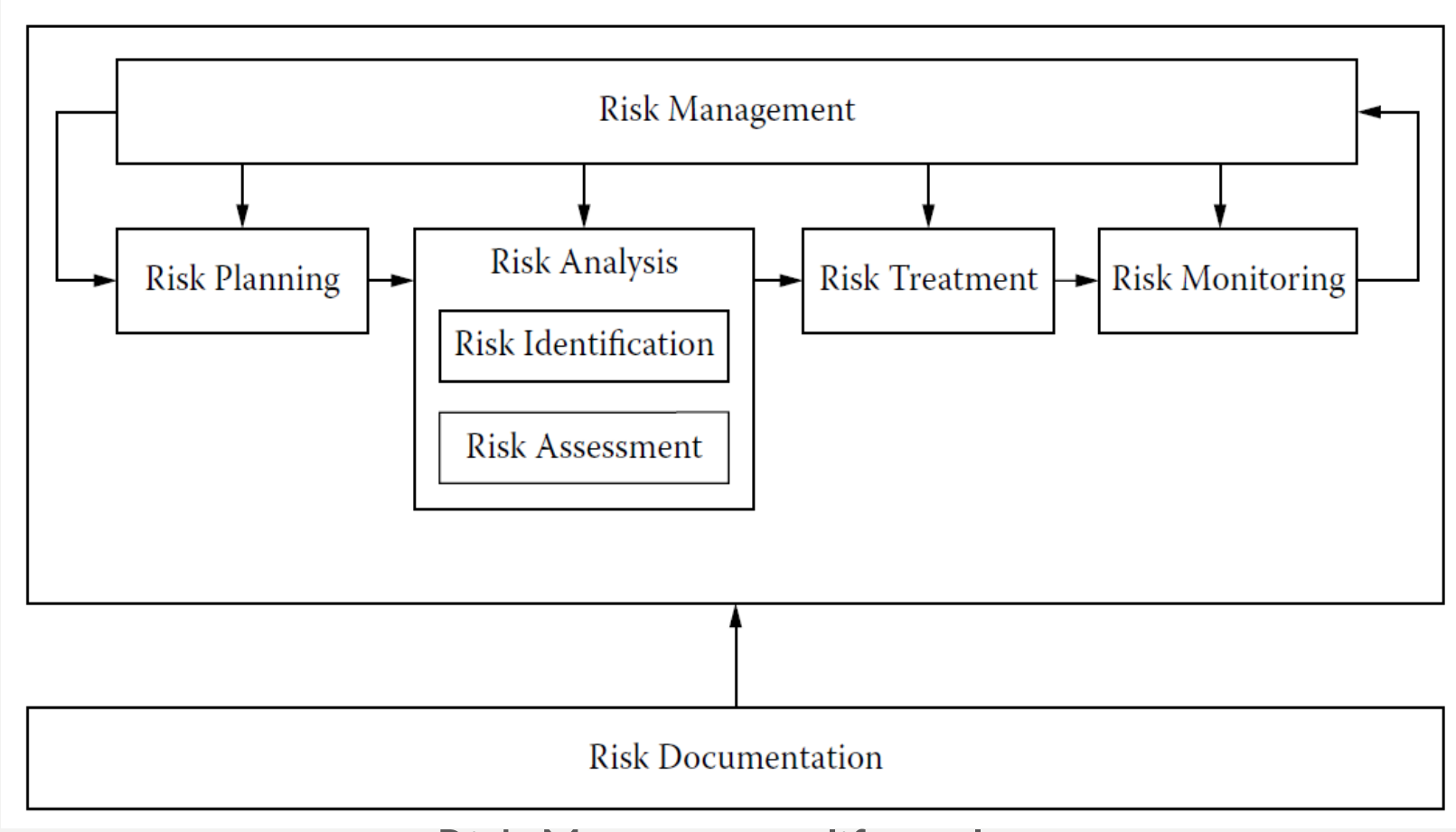
- **Risk management**: It is the activity of controlling risk to maintain it within its acceptable range. It includes planning for risk, assessing risk areas, developing risk-treatment options, monitoring risks to determine how risks change, and documenting the overall risk management program.
- **Risk planning**: It is the process of developing and documenting an organized, comprehensive, and interactive strategy and methods for identifying and tracking risk areas, developing risk treatment plans, performing continuous risk assessments to determine how risks change, and assigning adequate resources.
- **Risk assessment**: It is the determination of the level of risk and the potential impact of identified risk by measuring the likelihood and impact if associated incidents were to take place. Risk assessment is needed to prioritize any risk treatment effort devised to protect the system in question. The amount of risk assessed will be compared against expected benefits before any risk treatment is approved.

INFORMATION SECURITY RISK MANAGEMENT

- **Risk analysis:** It is the process of examining each identified risk area or process to refine the description of the risk, isolate the causes, and determine the effects. It includes risk rating and prioritization, in which risk events are defined in terms of their probability of occurrence, severity of consequence/impact, and relationship to other risk areas or processes.
- **Risk treatment**: It is the process of defining, selecting, and implementing security controls in order to bring back risks to acceptable levels as defined in the security policy. This includes the terms of what should be done, when it should be accomplished, who is responsible, the schedule, and relevant costs.
- **Risk monitoring**: It is the process of systematically tracking and evaluating the performance of risk treatment actions against established metrics and developing further risk treatment options, as needed. This process revisits the other risk management activities of planning, analysis, and treatment.

INFORMATION SECURITY RISK MANAGEMENT

- **Risk documentation**: It is the recording of information describing various phases of risk management.



Risk Management life cycle.

INFORMATION SECURITY RISK MANAGEMENT

- The loss of confidentiality, integrity, or availability of an asset will translate into loss of business value to the organization.
- The organization will also lose its reputation, the trust of its partners and customers, in addition to many other undesirable social outcomes.
- If you believe that there are threats, internal or external, that menace the normal business-value-generation capability of a given asset, then this asset is at risk.
- Owners
  - must be aware of asset exposure conditions that can increase the risk of damage to the asset that can occur as a result of attacks by known threats.
  - need to reduce the risk that the regular business value generated by an asset would decline if certain exposure conditions occur in the computing environment.

INFORMATION SECURITY RISK MANAGEMENT

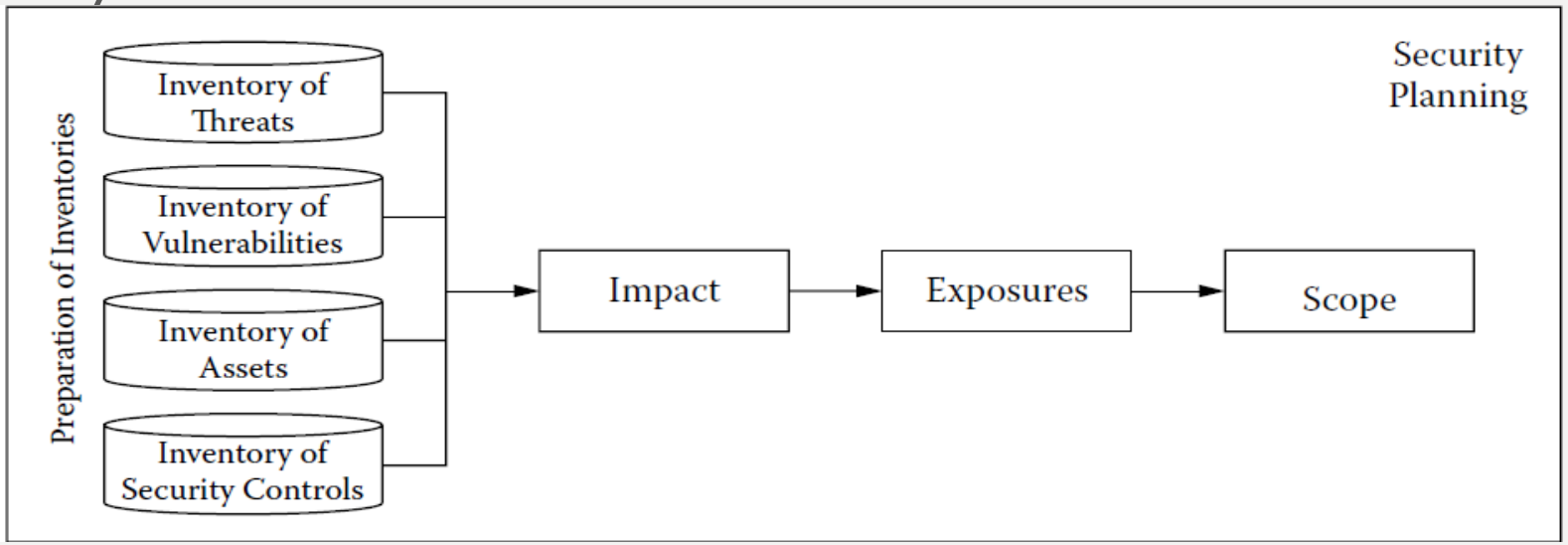
- Organizations should be clear about their security objectives and the risks they are willing to tolerate.
- Owners should understand the business objective set for their assets.
- They are responsible for defining the levels of risk they are willing to tolerate for their assets.
- The asset security policy should state the tolerated risk level of the asset.
- The organization's security policy should include the tolerated risk levels for all systems and assets belonging to the organization.
- Each functional unit, division, and department should have a policy manual with clearly stated objectives and constraints so that employees and users know the type of risks taken by the organization.

INFORMATION SECURITY RISK MANAGEMENT

- Information needed to manage risk
  - There are risks anywhere you look in an organization
  - Every asset in the organization is at risk.
  - Some assets will, however, be associated with risks lower than the risk level tolerated by management, and others will be menaced by risks higher than the accepted risk levels determined by owners for those assets.
  - In the former case, the risk level associated with the asset is accepted by owners, and no additional security will be provided to the asset.
  - In the latter case, the risk level is higher than the tolerated level, and there is an immediate need to invest in securing the asset enough to take it back to an acceptable risk position.

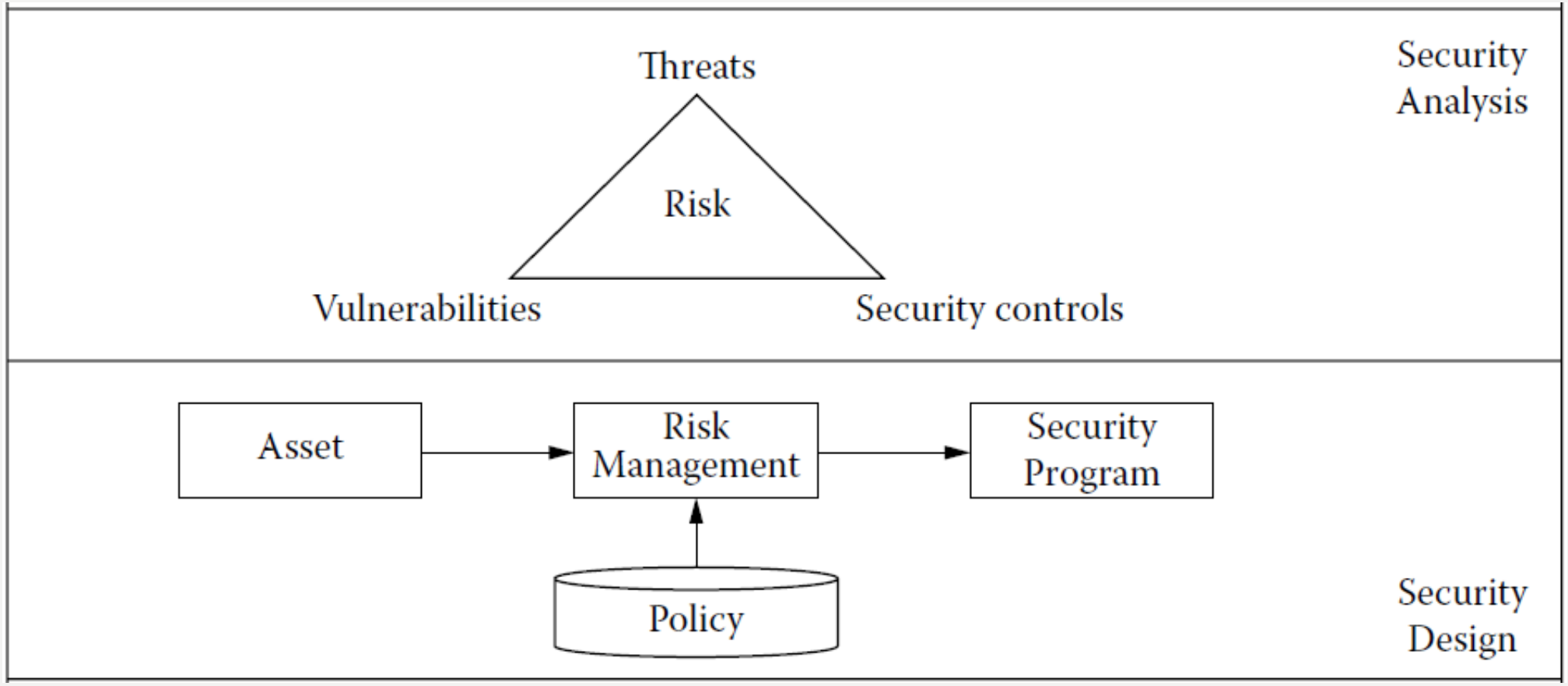
INFORMATION SECURITY RISK MANAGEMENT

- Information needed to manage risk
  - In order to manage risks, security management needs to identify risks, assess them, and mitigate them.
  - Security management must collect information about assets and their vulnerabilities, threats, the organization's current security policies, and the current security controls.
  - The picture depicts the transition from basic risks to mitigated risks by the application of the appropriate security controls.
  - AT security planning phase



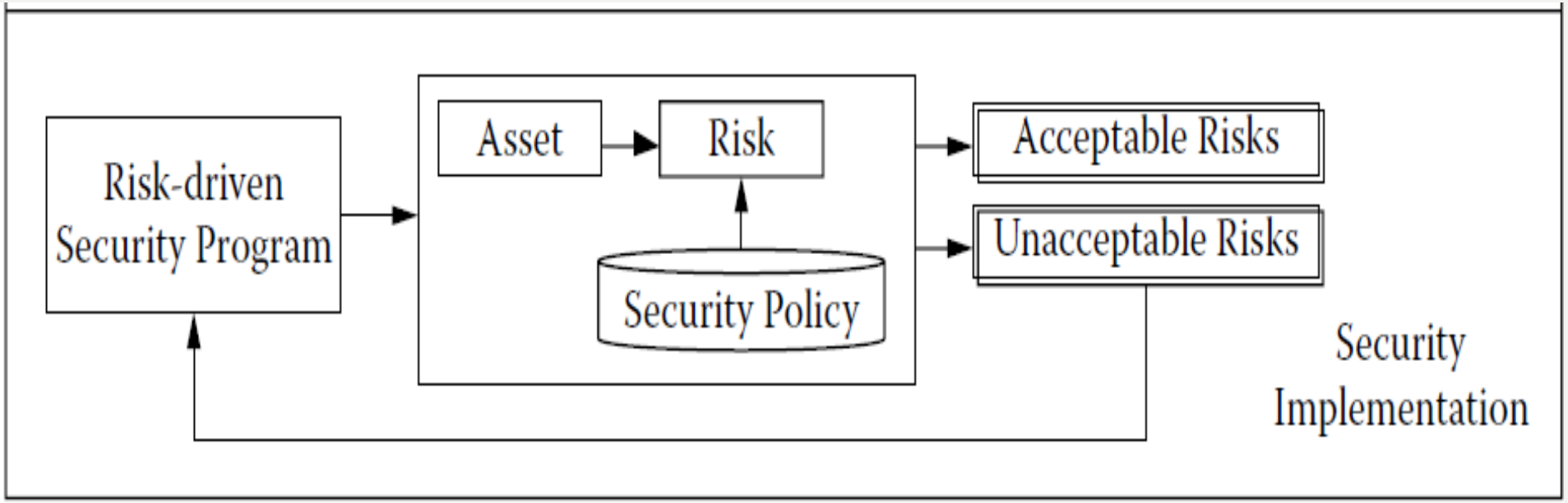
INFORMATION SECURITY RISK MANAGEMENT

- Information needed to manage risk
  - At security Analysis and Design phases



INFORMATION SECURITY RISK MANAGEMENT

- Information needed to manage risk
  - At implementation phase

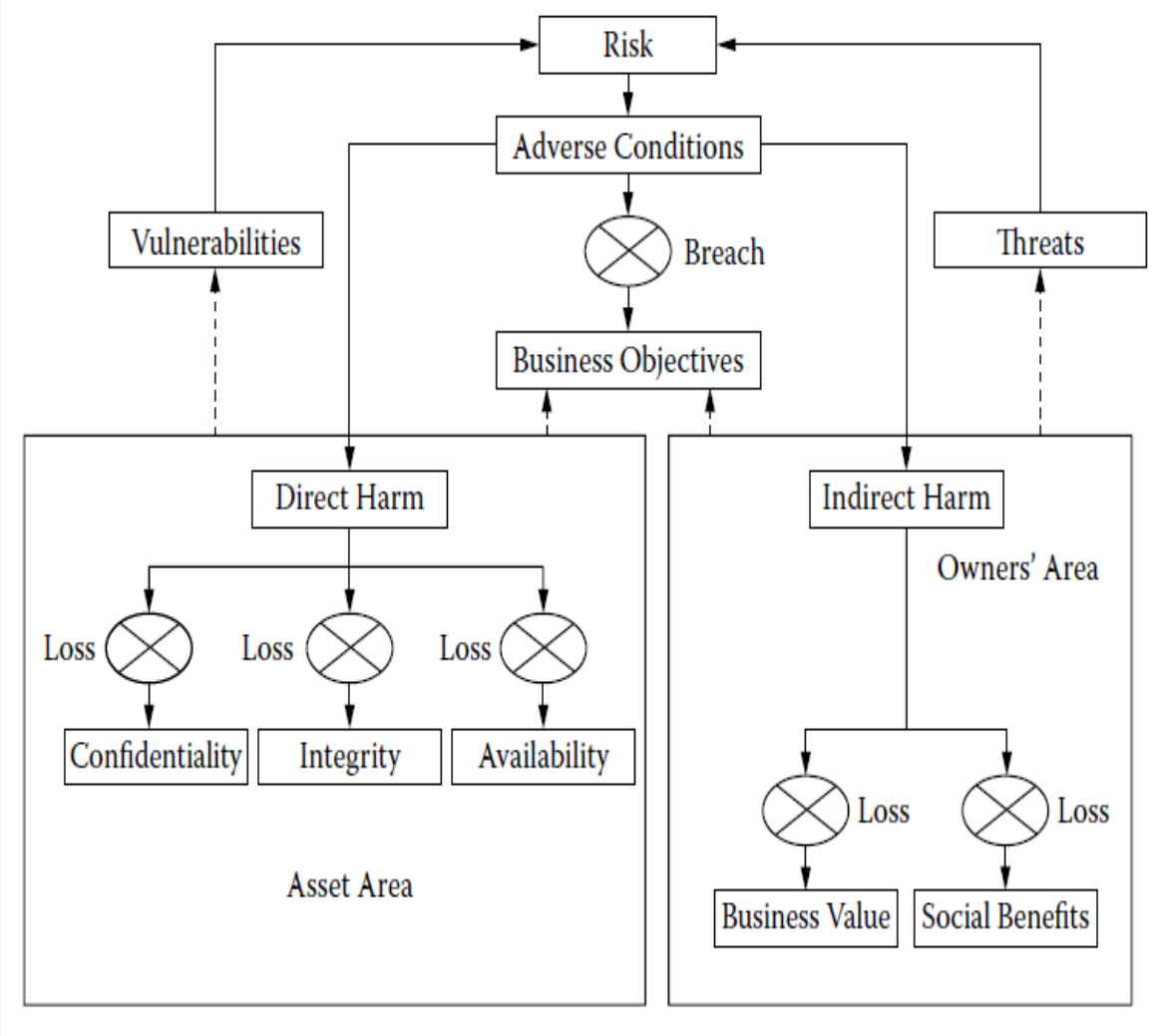


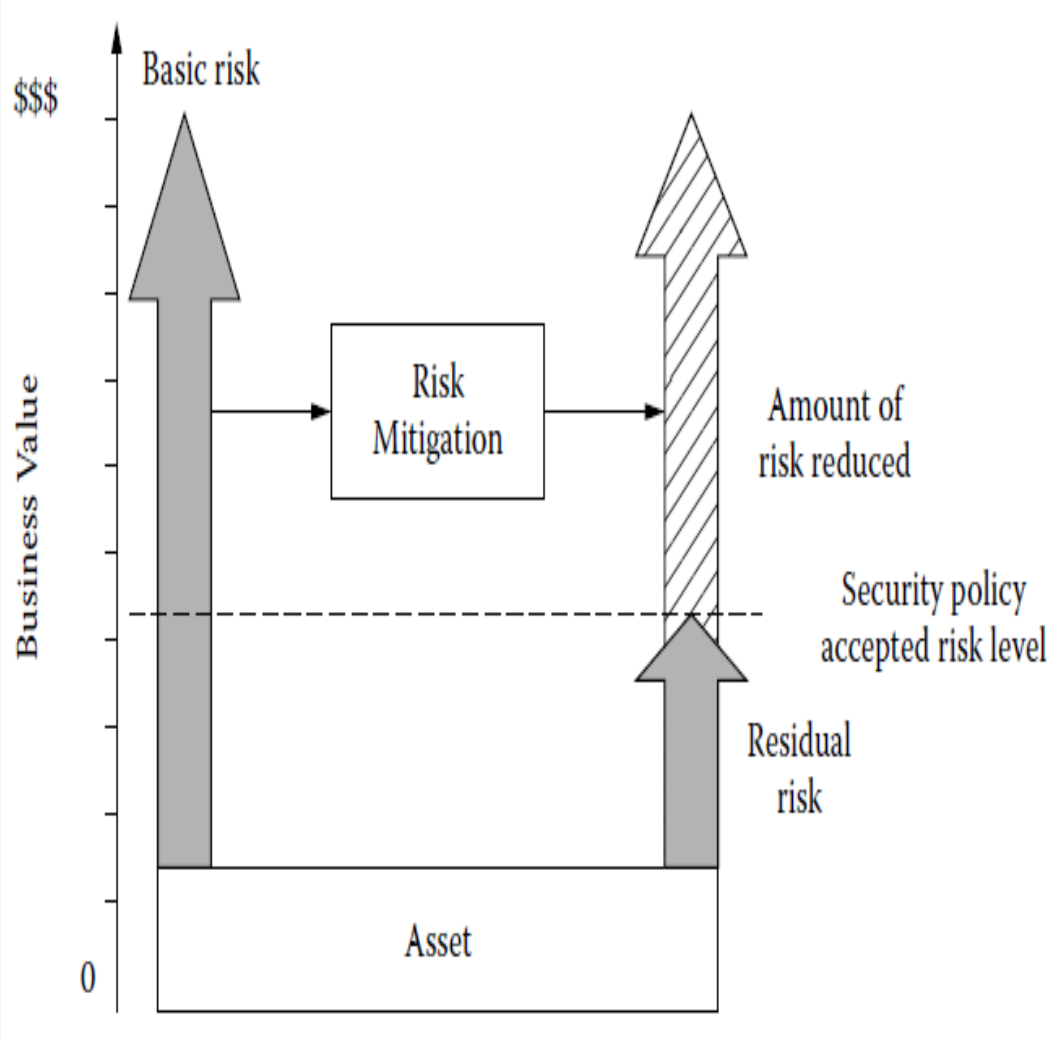
INFORMATION SECURITY RISK MANAGEMENT

- Security recovery
  - The security management of the victim asset determines how the recovery process is planned.
  - Corrective actions are performed in two modes: compromised productivity mode, or full unavailability mode.
- Risks can appear at any level of business management:
  - Strategic level: risks associated with strategic planning activities
  - Functional level: risks concerned with functional performance
  - Operational level: risks concerned with operational activities
- The organization must identify, assess, and mitigate risks at every managerial level.
  - The asset security policy should state the tolerated risk level of the asset.
  - The adverse condition is often expressed in terms of two components: a weakness in the asset and a threat capable of exploiting this weakness to cause harm to the asset.

INFORMATION SECURITY RISK MANAGEMENT

- How risk is mitigated





INFORMATION SECURITY RISK MANAGEMENT

- All employees should have a sustainable security culture
- Security management should be aware of the organization's weaknesses and vulnerabilities that increase the organization's exposures to existing threats.
- Security awareness, literacy, training, and education are all important components of the new security culture.
- Security management should ensure that undesired events do not occur, by planning the necessary prevention and mitigation actions needed to improve the security position of the organization.
  - Preventive actions attempt to counter the possibility that an event will result in intolerable losses.
  - Mitigation actions, on the other hand, concern processes to reduce vulnerability to known threats.
- In this manner, security management can manage security risks.

PLAN

- Active security assessment
  - Standards for active security assessment
  - Limits of active security assessment
  - The vulnerabilities of various components of the computing environment
  - Strategies for active security assessment
  - The active security assessment project
  - How to conduct passive security assessment
  - How to conduct the active security assessment effort

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- Major activities in security management include security planning, intrusion detection, risk management, and security auditing.
- Activities among these require major testing activities that include both passive and active security assessment.
- There are many types of testing activities presented in the literature with different names, such as vulnerability assessment, penetration testing, ethical hacking, and security assessment.
- These testing activities have single definitions acceptable to all.
- Penetration testing activities (as we are interested on it in this section) are variously defined, depending on the security objectives, test scope, and test security policy.
- Everyone agrees on the fact that the penetration test consists of active testing activities where the work of hackers is simulated.
- This simulation embraces hackers' effort when they discover, identify system vulnerabilities, and exploit them.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- A penetration test is an active security assessment that is performed according to a well-defined security objective, a well-defined scope, and a well-defined penetration security policy.
- This security assessment activity must
  - Blindly discover access information,
  - Identify system vulnerabilities,
  - Exploit them for the purpose of studying the system ability to resist adverse actions that can potentially compromise system security, and
  - Generate security recommendations and act upon them according to the assigned penetration security policy.
- No test can be useful in security management if it does not provide a comprehensive look at all aspects of the target system, including people, activities, data, infrastructure, and technology.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- To distinguish between many view of penetration testing and other views that take more myopic approaches in penetration testing, we propose using the name of active security assessment (ASA) instead.
- There are many standards and guidelines that apply to various security planning and auditing activities, and security in general.
- We mention some activity here because they may be useful in guiding your testing activities in several ways.
- There are many standards that you can adopt when planning your active security assessment project: ISO 17799, ISO 27001-05, BS 25277, NIST Security Plan Guidelines, and OSSTMM.
- We may not be able to stop everything hackers do but we can make it difficult for them to harm us, and we certainly can minimize the effects of their malicious work on our systems.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- In an ASA project, it is proper that systems owners give testers permission to simulate what hackers do from the early foot printing effort to the final effort of reporting the effects of testers' attempts to exploit the identified systems vulnerabilities.
- If you are a penetration tester, you will then act like a real hacker, but your penetration testing activities are limited.
  - That is, a penetration test, also called **ethical hacking**, consists of a sequence of penetration activities authorized by systems owners.
- An active security assessment project is intended to:
  - Explore what real hackers can do without causing damage to the target system
  - Identify risks
  - Explain risks to system owners
  - Generate recommendations to counter any intrusion aspects seen when hacking activities are simulated

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- Here are some differences between real hackers and testers:
  - Testers have a **security objective** to respect, and a real hacker has a **destructive objective** to expend as much as possible.
    - While testers are limited by the scope of penetration testing activities, which limits the techniques and the tools to use, the real hacker who has a destructive objective to achieve is not limited to any techniques or tools.
  - Testers have a **security policy** to comply with, but the hacker is not bothered with such restraints.
    - While testers attempt to record every single step taken to study effects and possible remedies, the real hacker will attempt to hide the traces of all steps to make it difficult for forensic analysts to identify or catch.
- ASA testers **simulate hackers** for the purpose of identifying, studying by exploiting, and mitigating risks caused by vulnerabilities in the target system.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- How ASA testers simulate their ethical attackers on various components of the information system.
  - On people: target people holding critical positions and manipulate them, through social engineering, to trick them into divulging information that can be of use to them to penetrate protected components in the target system.
  - On infrastructure (physical): testers can break into rooms or facilities containing assets to be stolen or physically damaged (laptops, desktops, printers, servers … etc.).
  - Common infrastructure attacks are:
    - Lower-layer attacks: when an attacker has access to a physical link, this often results in downtime for the link.
    - Generic DoS on the router: this attack is initiated by overloading a router using various techniques (sending some packets directed at the router itself, sending traffic exceeding the router's forwarding capacity, … etc.)

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- How ASA testers simulate their ethical attackers on various components of the information system.
  - Common infrastructure attacks are:
    - Cryptographic exhaustion attacks: the previous attack may manifest in many other ways, some of them more malicious, such as those attacks targeting a protocol that uses cryptographic mechanisms
    - Unauthorized neighbor attacks: sometimes when authentication is not adequate, unauthorized nodes obtain a routing protocol adjacency, and this may result in many kinds of attacks including traffic redirection.
    - TCP RST attacks: TCP sessions can be terminated by attackers who can send a TCP RST packet with guessed spoofed endpoint identifiers and a sufficiently close sequence number.
    - ICMP attacks: it may be initiated by sending an ICMP type which indicates a hard-error condition. ICMP errors must be propagated to applications, and most applications detect the errors or by closing a connection or session

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- How ASA testers simulate their ethical attackers on various components of the information system.
  - On Technology: there are mainly two types of software components known to be continuously attacked: Operating systems and computer applications like HTTP, SMTP, PTP, and VoIP.
    - Once the operating system is known on a computer system, the hacker can exploit known vulnerabilities of the operating system and then conduct the appropriate attacks to cause higher destructive affects.
    - Hackers also often attack popular computer applications like HTTP, SMTP, FTP, and others. Attackers often do not need much resource to successfully complete their application attacks. Application-level attacks target resources limitations within the application and do not require many compromised intermediary systems or large bandwidth.
    - Proxy servers can therefore be used to hide the true origin of the attacker, and many are available for attackers to redirect their malicious traffic. Many of these proxy servers do not keep logs of connection attempts and could therefore successfully cover the true origin of the attacking host.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- How ASA testers simulate their ethical attackers on various components of the information system.
  - On data: If corrupted, data can cause extended damage to all output subsystems.
    - Hackers can corrupt data and information residing in all components of the information system. They can also attack the information system using denial of service attacks, and users will not be able to access the data or information they need in a timely manner.
    - Files containing critical information that are not adequately protected may be posted in systems with major vulnerabilities that rogue users and hackers can exploit in malicious ways.
    - More and more Web applications use databases widely to store data, which is accessed and modified infrequently.
    - Dynamic data is used to manage user sessions.
    - Database operations, however, incur overhead cost in terms of storage space and processor time.
    - Attackers need access to a large amount of bandwidth should they wish to attempt to flood the victims' Internet connection.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- How ASA testers simulate their ethical attackers on various components of the information system.
  - On Activities: it consist of all tasks, procedures, policies, and regulations.
    - Those activities can be easily corrupted by rogue insiders (people in organization with access to resources).
    - The security of activities in a computing environment extends to networks and the infrastructure that use those activities.
- Ethics of security testing is extensively covered and we now provide four important rules that need to be included in any code of ethics written especially for active security assessment.
  - Stick to the security objective and scope, and to enforce the project security policy.
  - Respect for privacy
  - Avoid any destructive effects
  - Report any violation of any code of ethics by a member of the penetration testing team.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- An active security assessment ASA project is a special IT project that you plan, analyze, design, implement, and use.
- The ASA plan should be approved and supported by top management.
- Users of the target system should not be alerted to the ASA project in order to prevent any change of usage behavior so that users will show normal behavior throughout the ASA project.
- The planning effort in active security assessment (ASA) is a very critical phase of the project.
- In this phase, you need to constitute the ASA team, define project objectives, delineate its scope, and write its security policy.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Target system and its components
  - Timing of the project
  - Risks to be accepted throughout the ASA project
  - Strategy of the project in terms of visibility, place, and direction
  - Delivery requirements
  - Response activities and testing limitations throughout the ASA project

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Target system and its components
    - The ASA project cannot start if the target system is not well defined.
    - It is very important to define all the components of the system that are also targeted in the ASA project
    - There may be components of the system that are intentionally left out, when the target system is large, and budget and timing constraints are restrictive
  - Timing of the project
  - Risks to be accepted throughout the ASA project
  - Strategy of the project in terms of visibility, place, and direction
  - Delivery requirements
  - Response activities and testing limitations throughout the ASA project

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Target system and its components
    - The ASA project cannot start if the target system is not well defined.
    - It is very important to define all the components of the system that are also targeted in the ASA project
    - There may be components of the system that are intentionally left out, when the target system is large, and budget and timing constraints are restrictive
  - Delivery requirements
    - The scope of the ASA project should define the deliverables and their timing throughout the ASA project.
    - Respecting the timing of those deliverables is critical for the success of the ASA project.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Timing of the project
    - The ASA project scope should define the timing of all major penetration test steps of the ASA project.
    - Determining when the ASA tests are conducted is critical in the ASA project.
    - Some ASA steps should not be initiated when the production system is running so that the production outputs are not affected by those steps.
    - Some testing activities may slow down the performance of some components of the target system, which may compromise the performance of the target system.
    - In many ASA projects, testing activities are performed in weekends, late at night, or early in the morning to eliminate any effects on productivity.
    - The scope of the ASA project should provide sufficient information regarding to what extent a ASA project is blind on visible.
    - Defining a framework for the pretesting and testing activities and the information collection process needed to guide the identification of system vulnerabilities will require defining a strategy for the ASA project.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

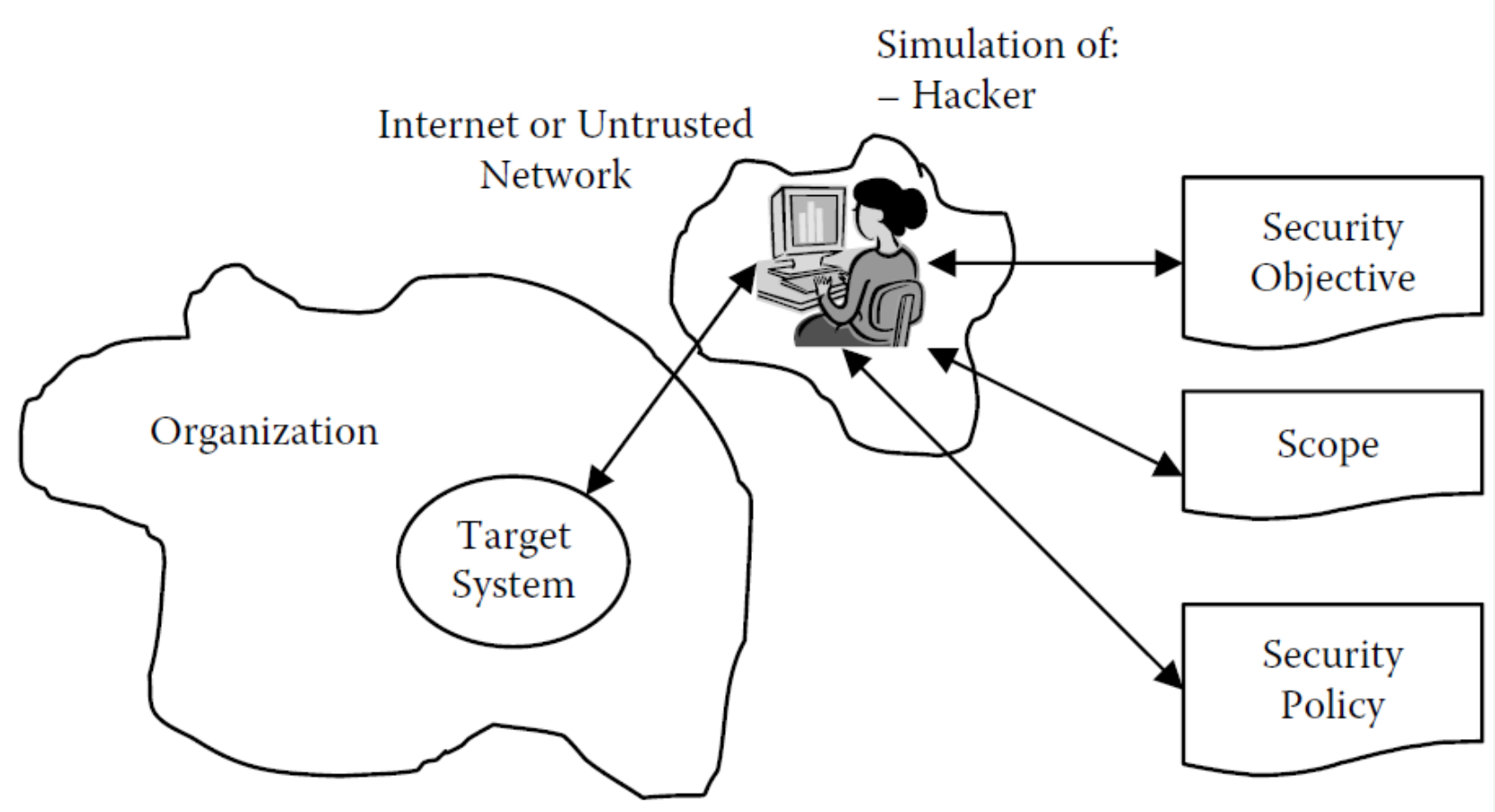
- The ASA project scope should specify that the following tasks are defined:
  - Risks to be accepted throughout the ASA project
    - What do the ASA testers do when immediate danger is discovered?
    - Can they just continue collecting information on more vulnerability until a final report is due to system owners?
    - Imagine the consequences if hackers exploit them to produce extended destructive power?
    - How can this ASA project be useful if the identified security holes remain open for hackers to exploit?
    - There should be some limited responses that ASA testers are allowed to take to prevent the exploitation of all identified vulnerabilities instead of waiting until the ASA report gets to security management who will then plan their responses.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Strategy of the project in terms of visibility, place, and direction
    - The place component expresses the position (external or internal) of the testers defined for the active security assessment project.
    - The visibility component is defined in terms of two variables:
      - v1, defining whether or not the tester obtains partial access information from systems owners before the starting of testing activities;
      - v2, defining whether or not systems users and management are informed of testing activities by system owners before the start of testing activities.
    - The third strategic component, direction, takes two values: one way or two ways.
  - Response activities and testing limitations throughout the ASA project

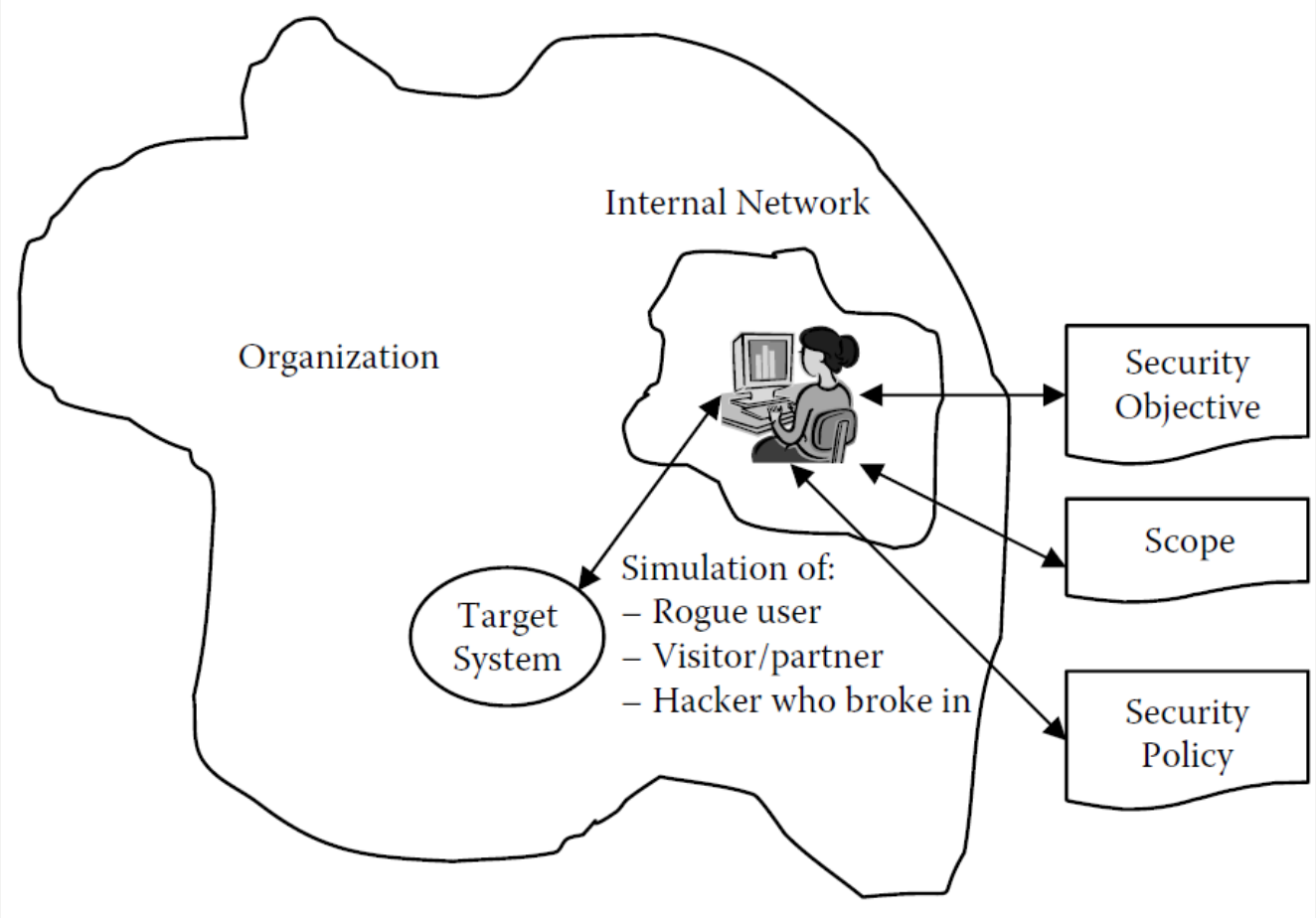
INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Strategy of the project in terms of visibility, place, and direction



INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Strategy of the project in terms of visibility, place, and direction



INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Strategy of the project in terms of visibility, place, and direction

Visibility Values	*The Tester Obtains Partial Access Information from System Owners before Testing Activities*	*Systems Users and Management are Informed of Testing Activities by System Owners before Testing Activities*
Double visible	Yes	Yes
Visible	Yes	No
Blind	No	Yes
Double blind	No	No

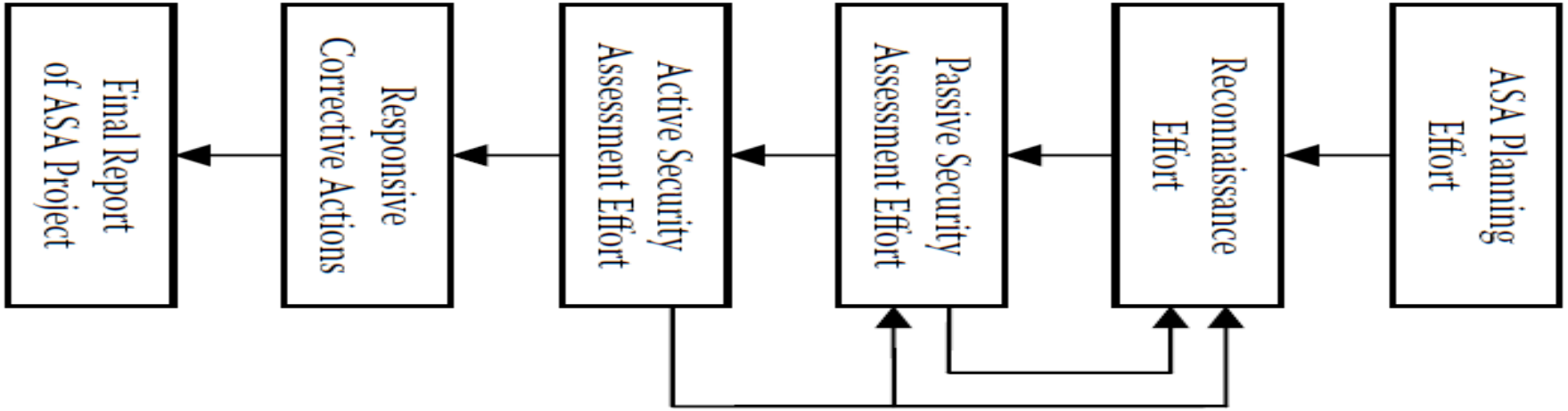
INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Strategy of the project in terms of visibility, place, and direction
    - The visibility value is
    - "Visible," when v1 = Yes and v2 = No;
    - "Double Visible," when v1 = Yes and v2 = Yes;
    - "Blind," when v1 = No and v2 = Yes;
    - "Double Blind," when v1 = No and v2 = No.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- The ASA project scope should specify that the following tasks are defined:
  - Strategy of the project in terms of visibility, place, and direction
    - The third strategic component, direction, takes two values: one way or two ways.
      - Direction strategy is concerned with double-active security assessment where warring is allowed between the testers and security management staff.
      - The warring strategy for active security assessment involves system security management and security assessment staff.
      - The warring setting may be synchronous or a synchronous.
      - In synchronous warring, active security assessment members attempt to hit internal systems while security management staff fights back by detecting and planning effective responses against intruder's attacks.
      - In asynchronous warring, active security assessment members attempt to hit internal systems for a fixed time period.
      - In a posterior time period, security management staff is allowed to fight back by detecting and planning effective responses against intruder's attacks in the future.
      - The active security assessment policy will set the rules defining interactions between system security staff and active security assessment staff.

INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT



INFORMATION SECURITY: ACTIVE SECURITY ASSESSMENT

- Conclusion:
  - As seen in the information security life cycle that good security design depends on a good security analysis.
  - A good security analysis however has to assess security effectiveness to redefine the security requirements assembled based on business impact analysis and risk analysis.
  - Security assessment may be conducted in a passive way, with invasive testing, or in an active way with guided penetration testing.